

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain E – Protect & Harden

Table of Contents

Domain E - Protective Technologies & Hardening.....	5
E1. Firewall Policy Agent	5
Agent Blueprint [Informative].....	5
Technical Implementation Details (E1) [Informative]	18
MCP-Native Protocol Specification (E1) [Normative]	20
E2. IPS Tuning Agent.....	21
Agent Blueprint [Informative].....	21
Technical Implementation Details (E2) [Informative]	35
MCP-Native Protocol Specification (E2) [Normative]	37
E3. Zero Trust Segmentation Agent.....	38
Agent Blueprint [Informative].....	38
Technical Implementation Details (E3) [Informative]	52
MCP-Native Protocol Specification (E3) [Normative]	54
E4. EDR Response Agent	55
Agent Blueprint [Informative].....	55
Technical Implementation Details (E4) [Informative]	67
MCP-Native Protocol Specification (E4) [Normative]	69
E5. Phishing Defense Agent	70
Agent Blueprint [Informative].....	70
Technical Implementation Details (E5) [Informative]	83
MCP-Native Protocol Specification (E5) [Normative]	85
E6. Cloud Security Agent.....	86
Agent Blueprint [Informative].....	86
Technical Implementation Details (E6) [Informative]	98
MCP-Native Protocol Specification (E6) [Normative]	100
E7. Baseline Enforcement Agent	101
Agent Blueprint [Informative].....	101
Technical Implementation Details (E7) [Informative]	114
MCP-Native Protocol Specification (E7) [Normative]	116

E8. Appsec Scanner Agent	117
Agent Blueprint [Informative]	117
Technical Implementation Details (E8) [Informative]	129
MCP-Native Protocol Specification (E8) [Normative]	131

Domain E - Protective Technologies & Hardening

E1. Firewall Policy Agent

Agent Blueprint [Informative]

Purpose: Manage firewall/NGFW rulesets and integrate intelligence courses of action (COAs) to reduce attack surface (block C2, contain lateral movement, enforce least privilege flows).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **IntelIOC (STIX/TAXII):** indicators with COA tags (e.g., coa:block, coa:contain), pattern expressions, validity windows.
- **RiskHotspot (Kafka/AMQP):** prioritized risky flows/segments from exposure analytics; includes risk_score, business_criticality, recommended_coa, TTL.
- **RCAFindings (REST/Object Storage):** incident root-causes, observed TTPs, lateral paths, network COA recommendations, evidence URIs.

Model training / knowledge (what the LLM relies on):

- Style/policy rubric for **least privilege, deny by default, zone-based segmentation, change-window discipline**, and vendor rule syntax norms.
- RAG over: policy/rulebase history, network zone inventory, service catalog, change tickets, previous RCA outcomes; **do not train on regulated evidence**—use evidence_refs.
- Guardrails: device and path allowlists; forbidden actions (e.g., permit any any); constrained tool scopes to NGFW/SDN change preview, simulation, and CAB ticket APIs only.

Decisions it makes (deterministic + model-assisted):

- **COA-to-rule translation:** map indicators/hotspots/RCA into canonical rule deltas (block, segment, restrict to bastion, time-bound denies).
- **Conflict/shadow detection:** detect duplicates, shadowed rules, precedence inversions; propose consolidate/disable order.
- **Blast-radius/simulation:** pre-change simulate hit counts and predicted false positive rate; veto if impact > thresholds.

- **Change gating:** enforce constraints=["change_window:offhours"] and CAB approvals when required; auto-schedule if missing.
- **Rollback criteria:** auto-rollback on elevated error rates or alert storms post-change.

Routing / where outputs go:

- **FWRuleChange** → NGFW/SDN controllers (REST/NETCONF/RESTCONF/GraphQL); side-effects: open/change CAB ticket, attach simulation report.
- **RuleAuditResult** → Governance/SIEM for attested audit line (who/what/why/hash), plus control references.
- Tickets/alerts on failure conditions, escalations to HITL on policy or impact thresholds.

Automation scope vs. manual/HITL:

- Fully automated: intel ingestion, COA translation, dedupe/shadow analysis, simulation, draft change generation, CAB ticket pre-fill.
- **HITL required:** production pushes on CrownJewels zones; any change with predicted benign-block-rate > 0.5 percent or change_impact_score >= 0.7; emergency blocks > 24 h TTL.
- Manual outside agent: new network macro-segmentation design; exception governance; vendor migration strategies.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **IntelIOC (STIX/TAXII)** — indicators and COA tags
2. **RiskHotspot (Kafka/AMQP)** — prioritized risky flows/segments from prioritization analytics
3. **RCAFindings (REST/Object Storage)** — incident root-cause and recommended network mitigations

Example: Consumed Protocol — IntelIOC (STIX/TAXII) [Informative]

Native payload

```
{
```

```

"type": "indicator",
"id": "indicator--7f2a1c8b-1b1c-4d0a-94d4-55d0f2e1aa90",
"created": "2025-08-15T11:30:00Z",
"pattern": "[domain-name:value = 'c2.bad-actor.example' OR ipv4-addr:value = '203.0.113.99']",
"labels": ["malicious-activity", "coa:block"],
"valid_from": "2025-08-15T11:30:00Z",
"external_references": [
  {"source_name": "CISA_KEV", "url": "https://example.kev/CVE-2025-12345"}
]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e1-intel-1111-2222-3333-4444",
    "thread_id": "uuid-stix-indicator--7f2a1c8b-1b1c-4d0a-94d4-55d0f2e1aa90",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "FirewallPolicyAgent",
    "intent": "implement",
    "constraints": ["change_window:offhours"],
    "policy_refs": ["CIS-9.1", "SC-7"],
    "decision_basis": {
      "evidence_refs": [
        "uri://taxii/indicators/indicator--7f2a1c8b-1b1c-4d0a-94d4-55d0f2e1aa90",
        "https://example.kev/CVE-2025-12345"
      ],
    },
  },
}

```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

    "confidence": 0.9,
    "explanation_ref": "uri://kb/fw/coa-intel-block"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/protect/fw-policy-agent",
    "signing_kid": "kid-stix-e1-01",
    "attestation_ref": "uri://slsa/attestations/fw-policy@sha256:stix01",
    "rule_sources": ["intel:stix:indicator--7f2a1c8b-1b1c-4d0a-94d4-55d0f2e1aa90"]
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — RiskHotspot (Kafka/AMQP) [Informative]
Native payload

```

{
  "hotspot_id": "RHS-2025-0815-021",
  "risk_score": 0.91,
  "segment": "prod/payments",
  "flow": {"src_cidr": "10.20.0.0/16", "dst_service": "0.0.0.0/0:3389/tcp"},
  "context": {
    "evidence": ["ASM:internet_facing", "SIEM:RDP_bruteforce"],
    "business_criticality": "CrownJewel"
  },
  "recommended_coa": ["block_inbound", "require_bastion"],
  "ttl_hours": 48
}

```

```
}
```

MCP-wrapped payload

```
{
```

```
  "mcp_context": {
```

```
    "mcp_version": "0.9",
```

```
    "mission_id": "uuid-e1-hotspot-5555-6666-7777-8888",
```

```
    "thread_id": "uuid-riskhotspot-RHS-2025-0815-021",
```

```
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
```

```
    "role": "FirewallPolicyAgent",
```

```
    "intent": "implement",
```

```
    "constraints": ["change_window:offhours"],
```

```
    "policy_refs": ["CIS-9.1", "SC-7"],
```

```
    "decision_basis": {
```

```
      "evidence_refs": ["uri://kafka/riskhotspot/RHS-2025-0815-021"],
```

```
      "confidence": 0.92,
```

```
      "explanation_ref": "uri://kb/fw/riskhotspot-prioritization"
```

```
    },
```

```
    "provenance": {
```

```
      "producer_spiffe": "spiffe://enterprise/protect/fw-policy-agent",
```

```
      "signing_kid": "kid-kfk-e1-02",
```

```
      "attestation_ref": "uri://slsa/attestations/fw-policy@sha256:kfk02",
```

```
      "rule_sources": ["riskhotspot:RHS-2025-0815-021"]
```

```
    },
```

```
    "classification": "C2",
```

```
    "legal_hold": false
```

```
  },
```

```
"native_payload": { ... as above ... }  
}
```

Example: Consumed Protocol — RCAFindings (REST/Object Storage) [Informative]

Native payload

```
{  
  "rca_id": "RCA-2025-0815-0042",  
  "incident_id": "INC-45877",  
  "observed_ttps": ["T1021.001: SMB", "T1071: Web C2"],  
  "lateral_paths": [  
    {"from": "10.20.7.14", "to": "10.20.19.55", "proto": "smb"},  
    {"from": "10.20.7.14", "to": "203.0.113.99", "proto": "https"}  
  ],  
  "recommendations_coa": [  
    {"type": "flow_block", "rule": "deny outbound to 203.0.113.99:443"},  
    {"type": "segmentation", "rule": "deny smb between user_net and db_net except  
bastion"}  
  ],  
  "evidence_uris": ["s3://dfir/INC-45877/pcap/session-22.pcap"]  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-e1-rca-aaaa-bbbb-cccc-dddd",  
    "thread_id": "uuid-rca-RCA-2025-0815-0042",  
    "task_id": "uuid-1122-3344-5566-7788",  
    "role": "FirewallPolicyAgent",  
  }  
}
```

```

"intent": "implement",
"constraints": ["change_window:offhours"],
"policy_refs": ["CIS-9.1", "SC-7"],
"decision_basis": {
  "evidence_refs": [
    "uri://s3/dfir/RCA-2025-0815-0042.json",
    "s3://dfir/INC-45877/pcap/session-22.pcap"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/fw/rca-to-rule"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/protect/fw-policy-agent",
  "signing_kid": "kid-rca-e1-03",
  "attestation_ref": "uri://slsa/attestations/fw-policy@sha256:rca03",
  "rule_sources": ["rca:RCA-2025-0815-0042"]
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **FWRuleChange** → NGFW/SDN APIs (REST/NETCONF/RESTCONF/GraphQL).
- **RuleAuditResult** → Governance/SIEM (Kafka/AMQP/REST).

MCP context (required) [Informative]

mission_id; role="FirewallPolicyAgent"; intent="implement";
constraints=["change_window:offhours"]; policy_refs=["CIS-9.1","SC-7"]; provenance
(SPIFFE ID, signing KID, rule source traceability)

MCP context (optional) [Informative]

classification (C1–C2 typical); decision_basis (evidence_refs, confidence,
explanation_ref); legal_hold; region

Enforcement note [Informative]

PEPs must verify **provenance.attestation**, **role="FirewallPolicyAgent"**,
change_window:offhours constraint, and **idempotency keys** before applying device
changes.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — adaptive protection and containment.

Automation feasibility [Informative]

High (proposal/simulation/autogeneration; production pushes gated by CAB/approvals
where required).

Output Contracts (merged) [Informative]

OC-1: FWRuleChange (NGFW/SDN rule delta) [Informative]

- **Producer(s):** E1
- **Topic/Path:** https://ngfw.api/v1/devices/{id}/rule-deltas or
netconf://controller/policies/deltas
- **Schema/Format:** **FWRulesetDelta@1.1** (canonical rule add/modify/disable;
includes zones, services, TTL, justification, simulation hash)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-device-id then by sequence
- **Idempotency-Key:** sha256(device_id, canonical_delta_hash,
valid_from_floor_60s)
- **Ack/Nack:** 2xx with change_id and commit_hash; NACK on 4xx/5xx with
diagnostics

- **Timeouts/Retry:** ack<=60 s; exp-backoff<=5x; circuit-breaker per device
- **Side-Effects:** open/update CAB ticket; attach simulation report; tag controls (SC-7, CIS-9.1)
- **HITL Token:** required for CrownJewels zones or change_impact_score >= 0.7
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=FWRulesetDelta@1.1 | json_schema_uri=uri://schema/fw-ruleset-delta-1.1.json | sha256= | producers=E1 | consumers=NGFW-01, SDN-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RuleAuditResult (post-change audit line) [Informative]

- **Producer(s):** E1
- **Topic/Path:** sec.governance.rule_audit (Kafka/AMQP/REST)
- **Schema/Format:** **FWRuleAudit@1.0** (who/what/why; pre/post hitcount; simulated vs. actual impact; hashes)
- **Classification:** C1–C2
- **Delivery:** at-least-once
- **Ordering:** per-change_id
- **Idempotency-Key:** sha256(change_id, commit_hash)
- **Ack/Nack:** 2xx with audit_id; retry/backoff on failure
- **Side-Effects:** append to GRC evidence store; link CAB ticket and device commit
- **HITL Token:** optional (requested by auditor)
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url, provenance.attestation

- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When SIEM/GRC audit integration is enabled

schema_id=FWRuleAudit@1.0 | json_schema_uri=uri://schema/fw-rule-audit-1.0.json | sha256= | producers=E1 | consumers=GRC-01, SIEM-01

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E1, Network-Change-Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-policy-id or per-change_id
- **Idempotency-Key:** sha256(policy_id_or_change_id, dispute_id)
- **Ack/Nack:** case_id<=30 s else retry/backoff
- **Side-Effects:** freeze conflicting deltas at PEP if severity high
- **HITL Token:** required when dispute severity >= high
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** E1
- **Topic/Path:** sec.policy.incident

- **Schema/Format:** IRPolicyViolationEvent@1.0
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, policy_id_or_change_id)
- **Ack/Nack:** SIEM/CaseID<=30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach rule delta and evidence_refs
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** per IR policy (>= 1 year)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (pre-change simulation summary) [Informative, optional]

- **Producer(s):** E1 (pre-commit)
- **Topic/Path:** sec.policy.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (hitcount deltas, predicted benign-block-rate, affected services/zones)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-proposal_id
- **Idempotency-Key:** sha256(proposal_id, simulation_hash)
- **Ack/Nack:** 2xx; retry/backoff
- **Side-Effects:** gate to staging/production per thresholds
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When change impact scoring/simulation gating is enabled
schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** NetOps Portal; E1 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, change_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to learning queue (governance reviewed)
- **Observability:** trace_id, mission_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_intel, deriving_coa, simulating, proposing, executing, verifying, auditing, contestation_workflow, rolling_back, failed, closed }
transition(idle -> ingesting_intel) when IntelIOC/RiskHotspot/RCAFindings arrive
transition(ingesting_intel -> deriving_coa) when validation passes
transition(deriving_coa -> simulating) when canonical_delta ready
transition(simulating -> proposing) when change_impact_score < 0.7 and benign_block_rate < 0.5 percent
transition(simulating -> contestation_workflow) when stakeholder_disagreement_score

≥ 0.5

transition(proposing -> executing) when change_window open AND approvals met

transition(executing -> verifying) when device commit ACK received

transition(verifying -> auditing) when post-change telemetry stable for 10 min

transition(verifying -> rolling_back) when alert_rate_spike or health_degradation detected

transition(* -> failed) on timeout/validation error

timeout(executing, 60 s) -> failed; retry ≤ 5 with exponential backoff

idempotency_key (FWRuleChange) = sha256(device_id, canonical_delta_hash, valid_from_floor_60s)

idempotency_key (RuleAuditResult) = sha256(change_id, commit_hash)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 FWRuleChange	Required	Always	Core enforcement of protections
OC-2 RuleAuditResult	Conditionally Required	SIEM/GRC audit integration enabled	Governance and accountability
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Simulation/impact scoring enabled	Risk-aware change gating
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met

- **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- policy_refs: **CIS-9.1, SC-7** (+ internal segmentation standards)
- **HITL required:** CrownJewels zone changes; predicted benign_block_rate > 0.5 percent; change_impact_score >= 0.7; emergency TTL > 24 h
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5
- **Manual outside agent:** macro-segmentation redesign; exception governance and variance approvals

SLOs and KPIs [Informative]

- ChangeProposalToSim_p95 <= 60 s
- ChangeCommitAck_p95 <= 60 s
- FalsePositiveBlockRate_7d <= 0.5 percent
- EmergencyBlockMTTR_p95 <= 5 min
- RollbackRate_30d <= 2 percent

Outputs index [Informative]

[OC-1 FWRuleChange], [OC-2 RuleAuditResult], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E1) [Informative]

Model and training profile [Informative]

model_id=protect-fw-text-model; temperature=0.1; max_tokens_out=700
prompt_pack_id=fw-policy-v1 (system prompt, COA mapping rubric, few-shots for vendor syntaxes)
RAG: sources={rulebase history, zone/service catalog, RCA store, CAB tickets};
max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: none initial; eval on rule correctness, false-positive bound
guardrails: device/zone allowlists; deny permit any any; max TTL for emergency blocks = 24 h without HITL

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (intel items, proposals, commits, audits),
ttl=365d
semantic_memory: namespaces=["network-zones","services","rules","rca"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced change log; snapshot per device nightly
consistency: at-least-once (proposals/audits); exactly-once (per device commit_id)
idempotency: as per Output Contracts

Decision and routing logic [Informative]

intel_confidence $\in$ [0,1]; exposure $\in$ [0,1]; business_criticality_map = {CrownJewel:1.0,
High:0.7, Med:0.4, Low:0.2}
$$\text{rule_risk_score} = 0.35\text{intel_confidence} + 0.25\text{risk_score} + 0.20\text{business_criticality} + 0.20\text{exposure}$$
$$\text{benign_block_rate} = \text{predicted_blocked_benign_flows} / \max(1, \text{predicted_total_blocks})$$
$$\text{change_impact_score} = 0.4\text{benign_block_rate} + 0.3\text{affected_services_ratio} + 0.2\text{shadow_conflict_risk} + 0.1\text{rollback_probability}$$

apply_if (rule_risk_score $\geq$ 0.6) AND (change_impact_score < 0.7) AND
(within_change_window = true)

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[vendor-syntax goldens, adversarial COA prompts]
thresholds: eval_pass_rate $\geq$ 99.5 percent $\rightarrow$ auto_HITL if below
red_team_cycle: monthly tests for bypasses (e.g., rule shadowing, overly broad ranges)
rollback_policy: eval_drop $\geq$ 1.5 percentage points for 48 h $\rightarrow$ revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: indicator/hotspot/rca refs; rule diff; simulation summary; hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; stable field order; retention per classification/legal_hold

Incident Response Integration [Informative]

SIEM route: IRPolicyViolationEvent (OC-4) on policy misses; link incident_id and change_id
SOAR playbooks: auto-open network containment cases with rollback hooks

Change Impact Assessment [Informative]

simulate pre-change → emit ChangeImpactReport (OC-5); enforce thresholds; require HITL when exceeded

Stakeholder Feedback Loop [Informative]

collect NetOps feedback via FeedbackIngestionEvent (OC-6); governance-reviewed updates to prompt_pack; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

region-aware deployments; route evidence_refs to in-region stores; legal_hold=true blocks purge

Interfaces (links only) [Informative]

Consumes: IntelIOC (STIX/TAXII); RiskHotspot (Kafka/AMQP); RCAFindings (REST/Object)

Produces: OC-1 FWRuleChange; OC-2 RuleAuditResult; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance/signature mismatch; sandbox simulation when attestations missing; blast-radius caps (≤ 50 rules/device/day; ≤ 5 emergency blocks/day)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of historical rule changes; red-team drills for shadowing/misorder; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-device concurrency caps; canary apply; auto-rollback on health alarms; SBOM + in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SC-7); CIS Controls v8 (9.1); NIST SP 800-61 Rev. 2; NIST SP 800-137; MITRE ATT&CK/D3FEND; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (E1) [Normative]

- **Native Protocol(s) Consumed:** IntelIOC (STIX/TAXII); RiskHotspot (Kafka/AMQP); RCAFindings (REST/Object Storage)

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Native Protocol(s) Produced:** FWRuleChange (NGFW/SDN APIs: REST/NETCONF/RESTCONF/GraphQL); RuleAuditResult (Kafka/AMQP/REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="FirewallPolicyAgent"; intent="implement"; constraints=["change_window:offhours"]; policy_refs=["CIS-9.1","SC-7"]; provenance (SPIFFE ID, signing KID, rule source traceability)
 - **Optional:** classification; decision_basis (evidence_refs, confidence, explanation_ref); legal_hold; region
- **Enforcement Note:** PEPs must verify provenance, change window, idempotency keys, and required approvals prior to commits.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges/EOL.
- **Example payloads:** native + MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E2. IPS Tuning Agent

Agent Blueprint [Informative]

Purpose: Adjust IDS/IPS signatures and thresholds to maximize detection value while minimizing false positives; auto-simulate, stage, deploy, and (if needed) roll back signature changes.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **SIEM Detections (REST/Query/OTel-logs):** per rule/SID alert rates, distinct assets, suppression stats, top false-positive reasons, traffic context.
- **False-Positive Feedback (SOAR/Ticketing or Kafka):** analyst labels with reasons and evidence links for specific SIDs and alerts.
- **Intel Feeds (STIX/TAXII):** indicators and courses of action that introduce new signatures or modify existing ones.

Model training / knowledge (what the LLM relies on):

- Style and rubric for precision-recall tradeoffs, staged rollout discipline, emergency rollback, and vendor syntax norms (Suricata/Snort/NGFW Threat Prevention).
- RAG over: historical signature efficacy, past false-positive clusters, device capability matrix, canary results, CAB tickets. Do not train on regulated evidence; use evidence_refs.
- Guardrails: allowlisted signature engines; disallow rules that match “any any” without constraint; tool scopes limited to simulation, staging, rollout, and rollback APIs.

Decisions it makes (deterministic + model-assisted):

- **Thresholding and actions:** raise threshold, add flow qualifiers, convert “alert” to “log” on noisy SIDs, or disable temporarily with TTL and rollback token.
- **New sig adoption:** from COA payloads; normalize to canonical signature schema; de-duplicate sids; assign safe default action=alert in stage.
- **Rollout plan:** canary percentage, stage duration, promotion gates using predicted and observed metrics.
- **Rollback:** trigger based on observed error budgets or health checks; use rollback_token and TTL controls.

Routing / where outputs go:

- **SigUpdate** → IPS managers (Suricata/Snort/NGFW) via vendor APIs; side-effects: create or update CAB ticket, attach simulation report.
- **TuningPlan** → governance and SIEM channels; side-effects: link to decision_rationale_url and evidence_refs.
- Tickets and alerts on simulation failure, staging regressions, or policy conflicts; HITL escalation when disables affect high-risk assets.

Automation scope vs. manual/HITL:

- Fully automated: data ingestion, clustering FP patterns, simulation, TuningPlan generation, canary apply, promotion if gates pass.
- **HITL required:** permanent disable on high-fidelity malware SIDs; action changes on CrownJewels segments; deviation from simulate_before_enforce.

- Manual outside agent: authoring novel detection logic beyond supported engines; vendor migration and platform upgrades.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **SIEM Detections (REST/Query/OTel-logs)** — alert rates by rule/SID, context metrics
2. **False-Positive Feedback (SOAR/Ticketing REST or Kafka)** — analyst labels with reasons/evidence
3. **Intel Feeds (STIX/TAXII)** — indicators and COAs suggesting new or updated signatures

Example: Consumed Protocol — SIEM Detections [Informative]

Native payload

```
{
  "window": "2025-08-14T00:00:00Z/2025-08-15T00:00:00Z",
  "rule_id": "suricata:ET-TROJAN Possible Orion C2",
  "sid": 2026765,
  "alerts_total": 18450,
  "distinct_assets": 112,
  "suppressed": 320,
  "true_positives": 47,
  "false_positives": 18321,
  "fp_top_reasons": ["backup_scan", "health_check", "cdn_falsehost"],
  "p95_bytes": 1420,
  "asn_top": ["AS15169", "AS16509"]
}
```

MCP-wrapped payload

```
{
```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-e2-siem-1111-2222-3333-4444",
  "thread_id": "uuid-sid-2026765-2025-08-14",
  "task_id": "uuid-a1b2-c3d4-e5f6-7788",
  "role": "IPSTuningAgent",
  "intent": "implement",
  "policy_refs": ["SI-4", "CM-6"],
  "constraints": ["rollback_token:sigset-2025-08-15-01", "rollback_ttl_minutes:120",
"simulate_before_enforce"],
  "decision_basis": {
    "evidence_refs": ["uri://siem/aggregate/sid/2026765/2025-08-14"],
    "confidence": 0.92,
    "explanation_ref": "uri://models/ips/precision-recall-thresholding"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/protect/ips-tuning-agent",
    "signing_kid": "kid-siem-e2-01",
    "attestation_ref": "uri://slsa/attestations/ips-tuning@sha256:siem01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — False-Positive Feedback [Informative]

Native payload

```
{
  "feedback_id": "FP-2025-0815-0041",
  "alert_id": "ALRT-9b1c",
  "sid": 2026765,
  "label": "false_positive",
  "reason": "scheduled backup traffic misclassified",
  "analyst": "sec.analyst",
  "timestamp": "2025-08-15T11:22:41Z",
  "evidence_refs": ["s3://siem/pcap/ALRT-9b1c.pcap"]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e2-fp-5555-6666-7777-8888",
    "thread_id": "uuid-fp-FP-2025-0815-0041",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "IPSTuningAgent",
    "intent": "implement",
    "policy_refs": ["SI-4"],
    "constraints": ["rollback_token:sigset-2025-08-15-01", "simulate_before_enforce"],
    "decision_basis": {
      "evidence_refs": [
        "uri://soar/feedback/FP-2025-0815-0041",
        "s3://siem/pcap/ALRT-9b1c.pcap"
      ],
    }
  }
}
```

```

    "confidence": 0.9,
    "explanation_ref": "uri://kb/ips/fp-handling#allowlist-or-threshold"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/protect/ips-tuning-agent",
    "signing_kid": "kid-fp-e2-02",
    "attestation_ref": "uri://slsa/attestations/ips-tuning@sha256:fp02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — Intel Feeds (COA) [Informative]

Native payload

```

{
  "type": "course-of-action",
  "id": "course-of-action--c0a9cfe1-7e91-49a0-b67f-2ab6f9d2f2c7",
  "created": "2025-08-15T10:10:00Z",
  "name": "Deploy Suricata rule for Orion C2 URI pattern",
  "description": "Detect outbound HTTP requests with URI '/orion/v2/collect' to known bad hosts.",
  "x-signature": {
    "engine": "suricata",
    "sid": 3100450,
    "rev": 1,

```

```
"rule_text": "alert http any any -> $EXTERNAL_NET any (msg:\"ORION C2 beacon\";
urilen:14; content:\"/orion/v2/collect\"; http_uri; sid:3100450; rev:1;)"
```

```
},
```

```
"external_references": [
```

```
  {"source_name": "ThreatResearch", "url": "https://example.tr/orion-c2"}
```

```
]
```

```
}
```

MCP-wrapped payload

```
{
```

```
  "mcp_context": {
```

```
    "mcp_version": "0.9",
```

```
    "mission_id": "uuid-e2-intel-aaaa-bbbb-cccc-dddd",
```

```
    "thread_id": "uuid-coa-course-of-action--c0a9cfe1-7e91-49a0-b67f-2ab6f9d2f2c7",
```

```
    "task_id": "uuid-1122-3344-5566-7788",
```

```
    "role": "IPSTuningAgent",
```

```
    "intent": "implement",
```

```
    "policy_refs": ["SI-4", "CM-6"],
```

```
    "constraints": ["rollback_token:sigset-2025-08-15-01", "simulate_before_enforce"],
```

```
    "decision_basis": {
```

```
      "evidence_refs": [
```

```
        "uri://taxii/coa/course-of-action--c0a9cfe1-7e91-49a0-b67f-2ab6f9d2f2c7",
```

```
        "https://example.tr/orion-c2"
```

```
      ],
```

```
      "confidence": 0.94,
```

```
      "explanation_ref": "uri://kb/ips/coa-to-signature"
```

```
    },
```

```
    "provenance": {
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

    "producer_spiffe": "spiffe://enterprise/protect/ips-tuning-agent",
    "signing_kid": "kid-intel-e2-03",
    "attestation_ref": "uri://slsa/attestations/ips-tuning@sha256:intel03"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **SigUpdate** to IPS manager APIs (Suricata/Snort/NGFW Threat Prevention).
- **TuningPlan** (what to disable, tighten, or threshold-change) with simulation evidence.

MCP context (required) [Informative]

mission_id; role="IPSTuningAgent"; intent="implement"; constraints (e.g., rollback_token, rollback_ttl_minutes, simulate_before_enforce); policy_refs (e.g., SI-4, CM-6); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (C1–C2 typical); decision_basis (evidence refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs must verify **simulate_before_enforce** is honored, **rollback_token** is present for any disable, and provenance.attestation is valid before applying SigUpdate.

NIST SP 800-160v2 linkage [Informative]

Implement and Maintain — adaptive protections with verifiable rollback and provenance.

Automation feasibility [Informative]

High (auto-simulation and staged rollout; HITL only for high-risk disables).

Output Contracts (merged) [Informative]

OC-1: SigUpdate (signature add/modify/disable) [Informative]

- **Producer(s):** E2
- **Topic/Path:** <https://ips.api/v1/sigs/batch> or <https://ngfw.api/v1/threat-prevention/sigs>
- **Schema/Format:** **SigBatchDelta@1.1** (engine, sid, rev, action, rule_text or params, stage, canary_pct, ttl, rollback_token, simulation_hash)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-engine and per-device-group
- **Idempotency-Key:** sha256(engine, sid, rev, canonical_delta_hash, stage)
- **Ack/Nack:** 2xx returns change_id and commit_hash; NACK on 4xx/5xx with diagnostics
- **Timeouts/Retry:** ack<=60 s; exp-backoff<=5x; per-engine circuit breaker
- **Side-Effects:** open or update CAB ticket; attach simulation report; annotate policy_refs (SI-4, CM-6)
- **HITL Token:** required for permanent disables on high-fidelity malware SIDs or CrownJewels segments
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=SigBatchDelta@1.1 | json_schema_uri=uri://schema/ips-sig-batch-delta-1.1.json | sha256= | producers=E2 | consumers=IPS-Manager-01, NGFW-TP-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: TuningPlan (simulation and rollout gates) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Producer(s):** E2
- **Topic/Path:** sec.ips.tuning_plan (Kafka/AMQP/REST)
- **Schema/Format:** **IPSTuningPlan@1.0** (per SID: proposed change, predicted precision, recall, F1, false-positive delta, gates, canary plan, rollback_token, decision_rationale_url)
- **Classification:** C1–C2
- **Delivery:** at-least-once
- **Ordering:** per plan_id
- **Idempotency-Key:** sha256(plan_id, simulation_hash)
- **Ack/Nack:** 2xx with plan_id; retry/backoff on failure
- **Side-Effects:** create governance record; link to CAB; notify SIEM owners
- **HITL Token:** optional; required when plan includes disable on high-prevalence SID
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url, provenance.attestation
- **Retention/TTL:** 3 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When governance review or SIEM visibility is mandated for tuning
 schema_id=IPSTuningPlan@1.0 | json_schema_uri=uri://schema/ips-tuning-plan-1.0.json | sha256= | producers=E2 | consumers=GRC-01, SIEM-Owners-01

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E2, Analyst-Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-sid or per-plan_id

- **Idempotency-Key:** sha256(sid_or_plan_id, dispute_id)
- **Ack/Nack:** case_id<=30 s else retry/backoff
- **Side-Effects:** pause affected rollouts
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** E2
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (e.g., “tuning regression caused miss”)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, sid_or_plan_id)
- **Ack/Nack:** SIEM/CaseID<=30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach plan and SigUpdate deltas
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (pre-change simulation summary) [Informative, optional]

- **Producer(s):** E2 (pre-commit)
- **Topic/Path:** sec.ips.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (per SID metrics: predicted precision, recall, F1, expected alert delta, benign-block-rate)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-plan_id
- **Idempotency-Key:** sha256(plan_id, simulation_hash)
- **Ack/Nack:** 2xx; retry/backoff
- **Side-Effects:** gate promotion to stage/prod per thresholds
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When simulation gating is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Analyst-Portal; E2 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, sid_or_plan_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff

- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, aggregating_metrics, clustering_fp, deriving_plan, simulating, proposing, canary, staging, production, auditing, contestation_workflow, rolling_back, failed, closed }

- transition(idle -> aggregating_metrics) on SIEM window ready
- transition(aggregating_metrics -> clustering_fp) when data completeness >= threshold
- transition(clustering_fp -> deriving_plan) when FP clusters stabilized
- transition(deriving_plan -> simulating) when canonical delta built
- transition(simulating -> proposing) when gates pass
- transition(proposing -> canary) when approvals and change window satisfied
- transition(canary -> staging) when observed metrics meet promotion gates
- transition(staging -> production) when error budgets intact
- transition(production -> auditing) after commit and 10 min stable telemetry
- transition(any -> contestation_workflow) when PolicyDispute raised or stakeholder_disagreement_score >= 0.5
- transition(any -> rolling_back) when regression detected or rollback_ttl expires
- transition(* -> failed) on timeout or validation error

timeouts: simulate<=120 s; canary_observe>=30 min; stage_observe>=2 h

idempotency_key (SigUpdate) = sha256(engine, sid, rev, canonical_delta_hash, stage)

idempotency_key (TuningPlan) = sha256(plan_id, simulation_hash)

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 SigUpdate	Required	Always	Core protection tuning
OC-2 TuningPlan	Conditionally Required	Governance/SIEM visibility mandated	Auditability and coordination
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Simulation gating enabled	Risk-aware rollout
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- Required: Must be implemented for conformant deployment
- Conditionally Required: Must be implemented when trigger condition is met
- Optional: May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: **SI-4**, **CM-6** (+ internal IPS tuning standards)
- **HITL required:** permanent disable on high-fidelity malware SIDs; changes impacting CrownJewels segments; simulate_before_enforce=false requests
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5
- **Manual outside agent:** novel detection logic; platform upgrades

SLOs and KPIs [Informative]

- SimulateLatency_p95 <= 120 s
- CanaryPromotionDecision_p95 <= 35 min
- FalsePositiveRate_7d <= 0.5 percent on tuned SIDs
- MissedDetectionRegression_7d <= 0.1 percentage points absolute
- RollbackMTTR_p95 <= 5 min

Outputs index [Informative]

[OC-1 SigUpdate], [OC-2 TuningPlan], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E2) [Informative]

Model and training profile [Informative]

model_id=protect-ips-text-model; temperature=0.1; max_tokens_out=700
prompt_pack_id=ips-tuning-v1 (tradeoff rubric, rollout gates, vendor syntax few-shots)
RAG: sources={sig efficacy history, FP clusters, CAB tickets, device capability matrix};
max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; eval on parsing accuracy and rule correctness
guardrails: deny “any any” style expansions; cap action changes per window; require
rollback_token for disables

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (windows, clusters, plans, commits), ttl=365d
semantic_memory: namespaces=["signatures","devices","fp-clusters","intel-coa"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced journal; nightly snapshots per device-group
consistency: at-least-once (plans); exactly-once per change_id (SigUpdate)
idempotency: per Output Contracts

Decision and routing logic [Informative]

- $\text{precision} = \text{TP} / (\text{TP} + \text{FP})$
- $\text{recall} = \text{TP} / (\text{TP} + \text{FN})$
- $\text{F1} = 2 * \text{precision} * \text{recall} / (\text{precision} + \text{recall})$

- $fp_delta = (FP_after - FP_before) / \max(1, FP_before)$
- $recall_delta = recall_after - recall_before$
- $change_impact_score = 0.5 * \max(fp_delta, 0) + 0.3 * affected_assets_ratio + 0.2 * crownjewels_impact$
- $benefit_score = 0.5 * \max(recall_delta, 0) + 0.3 * threat_prevalence + 0.2 * intel_confidence$
- apply_if: (benefit_score >= 0.6) and (change_impact_score < 0.7) and simulate_before_enforce = true

Model Risk Management [Informative]

continuous_validation: daily goldens plus adversarial rule-text fuzzing

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly tests for overly broad or shadowed signatures

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who, what, why; before vs after metrics; simulation_hash; evidence_refs; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-4) when tuning is implicated in a miss; attach plan and delta; open SOAR case

Change Impact Assessment [Informative]

compute ChangeImpactReport (OC-5) pre-change; enforce thresholds; require HITL when exceeded

Stakeholder Feedback Loop [Informative]

ingest FeedbackIngestionEvent (OC-6) from analysts; incorporate into prompt_pack after governance review; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

regional routing of evidence_refs; legal_hold=true extends retention and blocks purge

Interfaces (links only) [Informative]

Consumes: SIEM Detections; False-Positive Feedback; Intel Feeds

Produces: OC-1 SigUpdate; OC-2 TuningPlan; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance/signature mismatch; sandbox-only changes when attestation missing; blast-radius caps (≤ 200 SIDs changed per 24 h; ≤ 20 disables per 24 h)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay on historical alert streams; red-team drills; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-device-group concurrency caps; canary then stage then production; auto-rollback on regression; SBOM + in-toto/SLSA; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-4, CM-6); NIST SP 800-61 Rev. 2; NIST SP 800-137; MITRE ATT&CK/D3FEND; CIS Controls v8

MCP-Native Protocol Specification (E2) [Normative]

- **Native Protocol(s) Consumed:** SIEM Detections (REST/Query/OTel-logs); False-Positive Feedback (SOAR/Ticketing or Kafka); Intel Feeds (STIX/TAXII)
- **Native Protocol(s) Produced:** SigUpdate (IPS manager APIs: Suricata/Snort/NGFW TP); TuningPlan (governance channel)
- **MCP Context Fields:**
 - **Required:** mission_id; role="IPSTuningAgent"; intent="implement"; constraints including rollback_token, rollback_ttl_minutes, simulate_before_enforce; policy_refs (SI-4, CM-6); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

- **Enforcement Note:** PEPs must verify `simulate_before_enforce`, presence and validity of `rollback_token` for disables, provenance attestation, and idempotency keys.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges and EOL.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E3. Zero Trust Segmentation Agent

Agent Blueprint [Informative]

Purpose: Enforce microsegmentation and policy-driven flows across data center, campus, and cloud fabrics; continuously adapt allow/deny based on asset labels, observed flows, and RCA containment guidance.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **CMDB / Asset Labels (REST/GraphQL):** identities, env and tiers, app and owner labels, `crown_jewel` tags, SPIFFE IDs, region and segment membership.
- **Flow Telemetry (Zeek/NetFlow/IPFIX/eBPF):** realized communications per 5-tuple with service hints; used to baseline candidate allow lists and detect drift.
- **RCAFindings (REST/Object Storage):** incident observations and segmentation recommendations for immediate containment and durable policy updates.

Model training / knowledge (what the LLM relies on):

- Style and rubric for **zero trust** (default deny, least privilege, identity before IP, deny unknown), **label semantics**, **east-west containment**, **simulation discipline**, and **co-sign in prod**.
- RAG over: label dictionaries, historical segmentation policy, approved service catalog, past RCA containments, cloud SG and NACL conventions, NSX-T/ACI/CNI object models. Do not train on regulated evidence; use `evidence_refs`.

- Guardrails: scope to approved SDN and NGFW controllers only; deny wildcards like 0.0.0.0/0 to CrownJewel targets; enforce simulate_before_enforce; require cosign for prod per constraints.

Decisions it makes (deterministic + model-assisted):

- **Label-to-policy derivation:** convert asset labels and service catalog into canonical intents (allow web→app 443/tcp with svc identity; deny db from user_net).
- **Baseline induction:** from stable flow telemetry windows, propose allow rules with identity qualifiers; reject flows lacking service identity or outside SLO baselines.
- **Containment actions:** from RCA, generate temporary FlowBlock with TTL and rollback plan; lift block when incident resolved or confidence falls.
- **Conflict and shadow detection:** detect overlapping CIDR and object-group rules, implicit allows, and order inversions; propose consolidation and explicit denies for clarity.
- **Promotion gating:** require co-signature for prod segments and pass simulation thresholds before enforce.

Routing / where outputs go:

- **SegmentationPolicy** → SDN/NGFW/CNI APIs (NSX-T, ACI, Calico/Cilium, cloud SG/NACL) with side-effects: CAB ticket update, simulation report, evidence links.
- **FlowBlock** → same controllers for temporary TTL blocks tied to an incident.
- Tickets/alerts on simulation failure, missing co-sign, or policy conflicts; HITL escalation where gates demand it.

Automation scope vs. manual/HITL:

- Fully automated: label ingestion, baseline candidate generation, simulation, proposal and CAB pre-fill, non-prod enforcement after gates.
- **HITL required:** any prod change on CrownJewel segments; rules that broaden trust boundaries; overrides of simulate_before_enforce; exceptions that reference 0.0.0.0/0.
- Manual outside agent: macro-segmentation architecture, new label taxonomy design, cross-tenant policy arbitration.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **CMDB / Asset Labels (REST/GraphQL)** — identities, env/tiers, ownership, crown-jewel tags
2. **Flow Telemetry (Zeek/NetFlow/IPFIX/eBPF)** — realized communications, baselining candidates
3. **RCAFindings (REST/Object Storage)** — incident COAs requiring segmentation/blocks

Example: Consumed Protocol — CMDB / Asset Labels [Informative]

Native payload

```
{  
  "asset_id": "srv-001",  
  "ip": "10.20.7.14",  
  "labels": ["env:prod", "app:payments", "tier:web", "crown_jewel"],  
  "spiffe_id": "spiffe://corp/payments/web/srv-001",  
  "owner_group": "payments.sre",  
  "segment": "seg:payments-web",  
  "region": "us-east-1"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-e3-cmdb-1111-2222-3333-4444",  
    "thread_id": "uuid-asset-srv-001",  
    "task_id": "uuid-aa11-bb22-cc33-dd44",  
    "role": "ZeroTrustSegmentationAgent",  
    "intent": "implement",  
  }  
}
```

```

"constraints": ["region:us-east-1", "cosign_required:prod", "simulate_before_enforce"],
"policy_refs": ["SC-7", "AC-4", "NIST-800-207"],
"decision_basis": {
  "evidence_refs": ["uri://cmdb/assets/srv-001"],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/zt/labels-to-segments"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/protect/zt-segmentation-agent",
  "signing_kid": "kid-cmdb-e3-01",
  "attestation_ref": "uri://slsa/attestations/zt-segmentation@sha256:cmdb01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — Flow Telemetry [Informative]
Native payload

```

{
  "ts": "2025-08-15T14:02:31Z",
  "id.orig_h": "10.20.7.14",
  "id.resp_h": "10.20.19.55",
  "id.resp_p": 3306,
  "proto": "tcp",
  "service": "mysql",
  "history": "ShADadFf",

```

```
"orig_bytes": 2819,  
"resp_bytes": 198473,  
"conn_state": "SF",  
"uid": "C7rV8q2qB2L5m0E9"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-e3-flow-5555-6666-7777-8888",  
    "thread_id": "uuid-conn-C7rV8q2qB2L5m0E9",  
    "task_id": "uuid-99aa-bbcc-ddee-ff00",  
    "role": "ZeroTrustSegmentationAgent",  
    "intent": "implement",  
    "constraints": ["region:us-east-1", "simulate_before_enforce"],  
    "policy_refs": ["SC-7", "AC-4", "NIST-800-207"],  
    "decision_basis": {  
      "evidence_refs": ["uri://zeek/conn/C7rV8q2qB2L5m0E9"],  
      "confidence": 0.9,  
      "explanation_ref": "uri://kb/zt/baseline-allowlist-derivation"  
    },  
    "provenance": {  
      "producer_spiffe": "spiffe://enterprise/protect/zt-segmentation-agent",  
      "signing_kid": "kid-flow-e3-02",  
      "attestation_ref": "uri://slsa/attestations/zt-segmentation@sha256:flow02"  
    },  
  },  
}
```

```

    "classification": "C1",
    "legal_hold": false
  },
  "native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — RCAFindings [Informative]

Native payload

```

{
  "rca_id": "RCA-2025-0815-0060",
  "incident_id": "INC-45902",
  "observations": [
    "Web tier initiating direct MySQL to DB without service account",
    "Outbound HTTPS to C2 203.0.113.99"
  ],
  "segmentation_recommendations": [
    { "effect": "deny", "from": "seg:payments-web", "to": "seg:payments-db", "port":
"3306/tcp", "condition": "missing_svc_identity" },
    { "effect": "deny", "from": "seg:payments-web", "to": "203.0.113.99/32", "port":
"443/tcp" }
  ],
  "evidence_uris": ["s3://dfir/INC-45902/flows/zeek/conn.gz"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e3-rca-aaaa-bbbb-cccc-dddd",

```

```

"thread_id": "uuid-rca-RCA-2025-0815-0060",
"task_id": "uuid-1122-3344-5566-7788",
"role": "ZeroTrustSegmentationAgent",
"intent": "implement",
"constraints": ["region:us-east-1", "cosign_required:prod", "simulate_before_enforce"],
"policy_refs": ["SC-7", "AC-4", "NIST-800-207"],
"decision_basis": {
  "evidence_refs": [
    "uri://rca/RCA-2025-0815-0060",
    "s3://dfir/INC-45902/flows/zeek/conn.gz"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/zt/rca-to-segmentation"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/protect/zt-segmentation-agent",
  "signing_kid": "kid-rca-e3-03",
  "attestation_ref": "uri://slsa/attestations/zt-segmentation@sha256:rca03"
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **SegmentationPolicy** → SDN/NGFW/CNI (NSX-T, ACI, Calico/Cilium, cloud SG/NACL APIs).

- **FlowBlock** → temporary TTL blocks for containment.

MCP context (required) [Informative]

mission_id; role="ZeroTrustSegmentationAgent"; intent="implement";
constraints=["region:us-east-1","cosign_required:prod","simulate_before_enforce"];
policy_refs=["SC-7","AC-4","NIST-800-207"]; provenance (SPIFFE ID, signing KID,
attestation)

MCP context (optional) [Informative]

classification (C1–C2); decision_basis (evidence_refs, confidence, explanation_ref);
legal_hold

Enforcement note [Informative]

PEPs must verify provenance.attestation, region constraint, simulate_before_enforce,
and **co-signature for prod segments** before enforcing. Deny 0.0.0.0/0 expansions to
or from CrownJewel assets without HITL.

NIST SP 800-160v2 linkage [Informative]

Implement and Maintain — adversary-resilient partitioning and containment; aligned
with NIST SP 800-207 Zero Trust Architecture.

Automation feasibility [Informative]

High (auto-generate policies from labels and flows; prod pushes co-signed and
simulation-gated).

Output Contracts (merged) [Informative]

OC-1: SegmentationPolicy (intent and compiled rules) [Informative]

- **Producer(s):** E3
- **Topic/Path:** <https://sdn.api/v1/policies/segmentation> or
<https://cloud.api/v1/sg/nacl/batch>
- **Schema/Format:** **ZTSegPolicy@1.1** (intents: subject, object, service, effect,
identity constraints; compiled backends for NSX-T, ACI, CNI, cloud SG/NACL;
includes simulation_hash and cosign_refs)
- **Classification:** C2
- **Delivery:** at-least-once

- **Ordering:** per-segment then per-policy-id
- **Idempotency-Key:** sha256(segment_id, canonical_policy_hash, region, valid_from_floor_60s)
- **Ack/Nack:** 2xx with policy_id and commit_hash; NACK on 4xx/5xx with diagnostics
- **Timeouts/Retry:** ack<=60 s; exp-backoff<=5x; per-controller circuit breaker
- **Side-Effects:** update CAB ticket; attach simulation report; tag controls (SC-7, AC-4, NIST-800-207)
- **HITL Token:** required for prod CrownJewel segments or trust boundary expansion
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ZTSegPolicy@1.1 | json_schema_uri=uri://schema/zt-seg-policy-1.1.json | sha256= | producers=E3 | consumers=SDN-01, NGFW-01, CNI-01, Cloud-SEC-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: FlowBlock (temporary containment rule) [Informative]

- **Producer(s):** E3
- **Topic/Path:** https://sdn.api/v1/blocks or https://cloud.api/v1/sg/temp-blocks
- **Schema/Format:** **ZTFlowBlock@1.0** (from, to, service, effect=deny, ttl, rollback_token, incident_id, simulation_hash)
- **Classification:** C2
- **Delivery:** exactly-once per incident_id and block_key
- **Ordering:** per-incident_id
- **Idempotency-Key:** sha256(incident_id, from, to, service, ttl_floor_60s)

- **Ack/Nack:** 2xx returns block_id; retry/backoff on failure
- **Side-Effects:** link SOAR case; schedule rollback or review on ttl expiry
- **HITL Token:** required for ttl > 24 h or when affecting shared core networks
- **Observability:** trace_id, mission_id, incident_id, decision_rationale_url, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When incident containment or RCA mandates temporary blocks

schema_id=ZTFlowBlock@1.0 | json_schema_uri=uri://schema/zt-flow-block-1.0.json | sha256= | producers=E3 | consumers=SDN-01, NGFW-01, Cloud-SEC-01

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E3, NetOps/Owner Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-policy-id or per-segment
- **Idempotency-Key:** sha256(policy_id_or_segment, dispute_id)
- **Ack/Nack:** case_id<=30 s else retry/backoff
- **Side-Effects:** freeze pending promotes for affected segments
- **HITL Token:** required when severity >= high
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** E3
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, policy_id_or_block_id)
- **Ack/Nack:** SIEM/CaseID<=30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach SegmentationPolicy or FlowBlock details
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (pre-enforcement simulation) [Informative, optional]

- **Producer(s):** E3 (pre-commit)
- **Topic/Path:** sec.zt.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (coverage deltas, predicted benign-block rate, affected services, hit counts)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-proposal_id
- **Idempotency-Key:** sha256(proposal_id, simulation_hash)
- **Ack/Nack:** 2xx; retry/backoff

- **Side-Effects:** gate promote to prod per thresholds and cosign
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When simulation gating is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Owner/NetOps Portal; E3 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, policy_id_or_segment)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, collecting_labels, baseline_learning, deriving_policy, simulating, proposing, cosigning, enforcing, auditing, contestation_workflow, rolling_back, failed, closed }

- transition(idle -> collecting_labels) on CMDB snapshot or delta
- transition(collecting_labels -> baseline_learning) when labels validated
- transition(baseline_learning -> deriving_policy) when candidate flows stable
- transition(deriving_policy -> simulating) when canonical intents built
- transition(simulating -> proposing) when gates pass
- transition(proposing -> cosigning) when target is prod or constraints require cosign
- transition(cosigning -> enforcing) when cosign verified and change window open
- transition(enforcing -> auditing) after commit and 10 min stable telemetry
- transition(any -> contestation_workflow) when PolicyDispute raised or stakeholder_disagreement_score >= 0.5
- transition(any -> rolling_back) when regression detected or ttl expires for FlowBlock
- transition(* -> failed) on timeout or validation error

timeouts: simulate<=120 s; cosign<=60 s; enforce_ack<=60 s

idempotency_key (SegmentationPolicy) = sha256(segment_id, canonical_policy_hash, region, valid_from_floor_60s)

idempotency_key (FlowBlock) = sha256(incident_id, from, to, service, ttl_floor_60s)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 SegmentationPolicy	Required	Always	Core microsegmentation enforcement

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-2 FlowBlock	Conditionally Required	Incident containment or RCA mandates temporary blocks	Rapid containment
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Simulation gating enabled	Risk-aware promotion
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- Required: Must be implemented for conformant deployment
- Conditionally Required: Must be implemented when trigger condition is met
- Optional: May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: **SC-7, AC-4, NIST-800-207** (+ internal segmentation standards).
- **HITL required:** prod CrownJewel segments; any trust-boundary expansion; rules referencing 0.0.0.0/0; simulate_before_enforce=false.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5.
- **Manual outside agent:** macro-segmentation definition; cross-tenant arbitration.

SLOs and KPIs [Informative]

- PolicyCompile_p95 <= 60 s

- EnforceCommitAck_p95 <= 60 s
- FalsePositiveBlockRate_7d <= 0.5 percent
- DriftDetect_MTTD <= 24 h
- EmergencyContainmentMTTR_p95 <= 5 min
- RollbackRate_30d <= 2 percent

Outputs index [Informative]

[OC-1 SegmentationPolicy], [OC-2 FlowBlock], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E3) [Informative]

Model and training profile [Informative]

model_id=protect-zt-text-model; temperature=0.1; max_tokens_out=700
 prompt_pack_id=zt-segmentation-v1 (zero-trust rubric, label semantics, simulator few-shots)
 RAG: sources={label dictionary, service catalog, historical policies, RCA store};
 max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval on policy correctness, identity qualifiers, and least-privilege adherence
 guardrails: deny broad CIDR to CrownJewel without identity; enforce
 simulate_before_enforce; require cosign for prod

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (labels, baselines, proposals, commits, RCA ties), ttl=365d
 semantic_memory: namespaces=["labels","segments","services","policies","rca"];
 embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced policy journal; nightly snapshots per segment
 consistency: at-least-once (proposals); exactly-once (per policy_id commit)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

- exposure = normalized frequency of a flow outside approved service catalog in baseline window

- $cj_weight = 1.0$ if either endpoint has crown_jewel label else 0.3
- $change_impact_score = 0.4 * predicted_benign_block_rate + 0.3 * affected_services_ratio + 0.2 * shadow_conflict_risk + 0.1 * rollback_probability$
- $benefit_score = 0.5 * exposure + 0.3 * cj_weight + 0.2 * intel_or_rca_signal_strength$
- apply_if: (benefit_score >= 0.6) and (change_impact_score < 0.7) and simulate_before_enforce = true
- require_cosign_if: target_environment = "prod" or segment_has_crown_jewel = true

Model Risk Management [Informative]

continuous_validation: daily goldens plus adversarial shadowing tests

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly tests for rule overlap, implicit allows, default-allow regressions

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: labels used, flow evidence, identity checks, simulation summary, hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-4) when segmentation miss implicated; attach FlowBlock and SegmentationPolicy references; open SOAR case

Change Impact Assessment [Informative]

emit ChangeImpactReport (OC-5) pre-enforcement; gate promotions; require HITL on threshold breach

Stakeholder Feedback Loop [Informative]

ingest FeedbackIngestionEvent (OC-6) from owners and NetOps; governance-review updates to prompt_pack; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

enforce region from constraints; route evidence_refs to in-region stores; legal_hold=true extends retention and blocks purge

Interfaces (links only) [Informative]

Consumes: CMDB/Asset Labels; Flow Telemetry; RCAFindings

Produces: OC-1 SegmentationPolicy; OC-2 FlowBlock; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance or cosign failure; sandbox simulation when attestation missing; blast-radius caps (≤ 100 policy changes per segment per day; ≤ 10 FlowBlocks open concurrently per fabric)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay on historical flows; red-team shadowing and overlap drills; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-controller concurrency caps; canary and staged promotion; auto-rollback on health alarms; SBOM + in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-207 (Zero Trust Architecture); NIST SP 800-53 Rev. 5 (SC-7, AC-4); NIST SP 800-61 Rev. 2; NIST SP 800-137; MITRE ATT&CK/D3FEND; CIS Controls v8

MCP-Native Protocol Specification (E3) [Normative]

- **Native Protocol(s) Consumed:** CMDB/Asset Labels (REST/GraphQL); Flow Telemetry (Zeek/NetFlow/IPFIX/eBPF); RCAFindings (REST/Object Storage)
- **Native Protocol(s) Produced:** SegmentationPolicy (SDN/NGFW/CNI and cloud SG/NACL); FlowBlock (temporary containment)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ZeroTrustSegmentationAgent"; intent="implement"; constraints=["region:", "cosign_required:prod", "simulate_before_enforce"];

policy_refs=["SC-7","AC-4","NIST-800-207"]; provenance (SPIFFE ID, signing KID, attestation)

- **Optional:** classification; decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PEPs must verify region constraint, simulate_before_enforce, and co-signature for prod segments, plus idempotency keys, before enforcement.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges and EOL.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E4. EDR Response Agent

Agent Blueprint [Informative]

Purpose: Execute endpoint response actions based on alerts and detections: kill process, quarantine file, isolate or de-isolate host; verify outcomes and emit EDRActionOutcome.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **EDR Alerts (REST/Webhook/Stream):** vendor alert objects with process/file/user/host context, severity, tactic/technique, asset tags.
- **DetectionEvent (Kafka/AMQP/REST):** normalized detection objects from the org's detection pipeline; includes recommendations and confidence.

Model training / knowledge (what the LLM relies on):

- Style/rubric for **containment safety, least-disruption, rollback-first discipline, and HITL gates on CrownJewels**.
- RAG over: vendor response APIs (capabilities and limits), playbooks by technique, historical action outcomes, rollback success rates, asset criticality registry. Do not train on regulated evidence; use evidence_refs.

- Guardrails: allowlisted actions {kill_process, quarantine_file, isolate_host, deisolate_host}; require rollback_ttl_minutes for isolates; deny file delete unless quarantine supported; tool scopes limited to simulate→execute→verify.

Decisions it makes (deterministic + model-assisted):

- **Action selection & ordering:** prioritize kill_process/quarantine_file before isolate_host unless strong lateral-movement or beaconing signal and/or CrownJewel tag.
- **HITL gating:** enforce hitl_required:isolate_if_tag=crown_jewel; require co-sign metadata when policy demands (see Enforcement note).
- **Rollback strategy:** set TTL and create pre-authorized rollback token; schedule verification probes and automatic de-isolate if verification fails.
- **Verification:** confirm expected state via EDR telemetry (process terminated, file quarantined, host network fenced) and emit EDRActionOutcome.

Routing / where outputs go:

- **Containment commands** → EDR vendor action APIs (native).
- **EDRActionOutcome** → detection bus (Kafka/AMQP/REST) and audit/SIEM; optional ticket update/comment in SOAR/ITSM.
- HITL requests/approvals recorded via governance channel when required.

Automation scope vs. manual/HITL:

- Fully automated: kill_process, quarantine_file; verify outcomes; emit EDRActionOutcome; schedule and execute time-boxed de-isolation on verification failure.
- **HITL required:** isolate_host on CrownJewel assets; any action when model_confidence < theta_low; override of rollback TTL; multi-host bulk actions.
- Manual outside agent: golden image re-provisioning, DFIR timeline creation, root-cause eradication beyond EDR's scope.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **EDR Alerts (REST/Webhook/Stream)** — vendor alert objects with process/file/user context

2. **DetectionEvent (Kafka/AMQP/REST)** — normalized detections from pipeline with recommendations

Example: Consumed Protocol — EDR Alerts [Informative]

Native payload

```
{
  "alert_id": "EDR-ALRT-2025-0815-7711",
  "vendor": "generic-edr",
  "hostname": "srv-001",
  "host_id": "edr-7f3c2a91",
  "severity": "High",
  "tactic": "Defense Evasion",
  "technique": "T1562.001",
  "timestamp": "2025-08-15T14:25:30Z",
  "user": "CORP\\svcapp",
  "process": {"pid": 4231, "name": "powershell.exe", "cmdline": "powershell -nop -w
hidden -enc ...", "sha256": "4f2d...c9e1"},
  "file": {"path": "C:\\Windows\\Temp\\orion.ps1", "sha256": "b1a2...9f03"},
  "detections": [{"rule_id": "CS1234", "name": "Suspicious LOLBAS PSBase64",
"confidence": 0.93}],
  "asset_tags": ["env:prod", "crown_jewel"],
  "primary_recommendation": "kill_process"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e4-edr-1111-2222-3333-4444",
    "thread_id": "uuid-alert-EDR-ALRT-2025-0815-7711",
```

```

"task_id": "uuid-a1b2-c3d4-e5f6-7788",
"role": "EDRResponseAgent",
"intent": "implement",
"constraints": ["hitl_required:isolate_if_tag=crown_jewel","rollback_ttl_minutes:60"],
"policy_refs": ["IR-4","SI-4","CM-6"],
"decision_basis": {"evidence_refs": ["uri://edr/alerts/EDR-ALRT-2025-0815-7711"]},
"confidence": 0.95, "explanation_ref": "uri://kb/edr/response-playbooks#powerShell-
lolbas"},
"provenance": {"producer_spiffe": "spiffe://enterprise/protect/edr-response-
agent","signing_kid":"kid-edr-e4-01","attestation_ref":"uri://slsa/attestations/edr-
response@sha256:edr01"},
"classification": "C3",
"legal_hold": true
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — DetectionEvent [Informative]

Native payload

```

{
"detection_id": "DET-2025-0815-7711",
"source": "EDR",
"category": "malware",
"rule": "Behavioral: Cobalt Strike Beacon",
"severity": "Critical",
"asset_id": "srv-001",
"asset_tags": ["env:prod","crown_jewel"],
"recommendations": ["isolate_host","kill_process","quarantine_file"],
"confidence": 0.93,

```

```

"ts": "2025-08-15T14:26:02Z",
"related_alerts": ["EDR-ALRT-2025-0815-7711"]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e4-det-5555-6666-7777-8888",
    "thread_id": "uuid-detection-DET-2025-0815-7711",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "EDRResponseAgent",
    "intent": "implement",
    "constraints": ["hitl_required:isolate_if_tag=crown_jewel","rollback_ttl_minutes:60"],
    "policy_refs": ["IR-4","SI-4"],
    "decision_basis": {"evidence_refs": ["uri://detections/DET-2025-0815-7711"],
"confidence": 0.94, "explanation_ref": "uri://kb/edr/containment#host-isolation-criteria"},
    "provenance": {"producer_spiffe": "spiffe://enterprise/protect/edr-response-agent", "signing_kid": "kid-det-e4-02", "attestation_ref": "uri://slsa/attestations/edr-response@sha256:det02"},
    "classification": "C3",
    "legal_hold": true
  },
  "native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **Vendor containment API calls:** kill_process, quarantine_file, isolate_host, deisolate_host.

- **EDRActionOutcome** event to bus; **audit events** to SIEM/SOAR; optional ticket comments/updates.

MCP context (required) [Informative]

mission_id; role="EDRResponseAgent"; intent="implement"; constraints including HITL/isolation rules (e.g., hitl_required:isolate_if_tag=crown_jewel, rollback_ttl_minutes:<n>); policy_refs (IR-4, SI-4, CM-6); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (often C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs/orchestrators MUST verify:

- For **host isolation** on CrownJewels: a valid HITL approval **and** a **co-signature** from the Governance Policy Agent (A1) if cosign_required applies;
- rollback TTL present for any isolation;
- provenance.attestation and idempotency key valid before executing actions.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — assured containment and recovery actions with verifiable outcomes and provenance.

Automation feasibility [Informative]

High for kill/quarantine; isolation is automatable but HITL/co-sign gated on high-impact assets.

Output Contracts (merged) [Informative]

OC-1: EDRActionOutcome (post-action verification & audit) [Informative]

- **Producer(s):** E4
- **Topic/Path:** sec.edr.action_outcome (Kafka/AMQP/REST)
- **Schema/Format:** **EDRActionOutcome@1.1** (action, target_type {host|process|file}, target_ids {host_id,pid,sha256}, request_ts, execute_ts,

verify_ts, status {succeeded|failed|partial}, verification_evidence_refs[],
rollback_token?, error?, policy_refs, decision_rationale_url, mission_id, trace_id)

- **Classification:** C3 (contains endpoint telemetry context)
- **Delivery:** at-least-once
- **Ordering:** per-target host_id
- **Idempotency-Key:** sha256(host_id, action, request_ts_floor_60s)
- **Ack/Nack:** 2xx returns outcome_id; retry/backoff on error
- **Timeouts/Retry:** verify<=120 s; exp-backoff<=5x
- **Side-Effects:** update SIEM/SOAR audit trail; comment on ticket if present
- **HITL Token:** none (outcome only)
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EDRActionOutcome@1.1 | json_schema_uri=uri://schema/edr-action-outcome-1.1.json | sha256= | producers=E4 | consumers=SIEM-01, SOAR-01, IR-DataLake-01 | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ContainmentCommand (action request envelope) [Informative]

- **Producer(s):** E4 (or SOAR on behalf of E4)
- **Topic/Path:** sec.containment.command (Kafka/AMQP/REST) or direct RPC to PEP/EDR gateway
- **Schema/Format: ContainmentCommand@1.0** (action, target, requested_by, reason, valid_until, cosign_refs[], hitl_approval_id?, rollback_ttl_minutes, evidence_refs[], policy_refs, mission_id, trace_id)
- **Classification:** C2–C3 (depends on evidence)

- **Delivery:** exactly-once per action_id (consumer enforces idempotency)
- **Ordering:** per-target host_id
- **Idempotency-Key:** sha256(action_id, host_id, valid_until_floor_60s)
- **Ack/Nack:** orchestrator ACK<=30 s; retry/backoff; NACK on missing co-sign/HITL
- **Side-Effects:** PEP executes vendor-native call; append immutable request to audit journal
- **HITL Token:** required when hitl_required:* constraint evaluates true
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.confidence, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When actions are orchestrated via a PEP/gateway or when co-sign/HITL policy applies

schema_id=ContainmentCommand@1.0 | json_schema_uri=uri://schema/containment-command-1.0.json | sha256= | producers=E4 | consumers=PEP-01, EDR-GW-01, SOAR-01

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E4, Analyst Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-action_id
- **Idempotency-Key:** sha256(action_id, dispute_id)
- **Ack/Nack:** case_id<=30 s else retry/backoff
- **Side-Effects:** freeze pending actions on same host_id if severity high
- **HITL Token:** required when severity >= high

- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (IR integration) [Informative, optional]

- **Producer(s):** E4
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (e.g., action failed or caused regression)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, action_id)
- **Ack/Nack:** SIEM/CaseID<=30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach EDRAActionOutcome and evidence
- **Observability:** trace_id, mission_id, policy_refs, incident_id
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (pre-action risk snapshot) [Informative, optional]

- **Producer(s):** E4 (pre-execute)
- **Topic/Path:** sec.response.change_impact

- **Schema/Format:** ChangeImpactReport@1.0 (business_process_risk, expected_user_disruption, dependency_hits, isolation_scope, rollback_plan)
- **Classification:** C1–C2
- **Delivery/Ordering:** at-least-once; per-action_id
- **Idempotency-Key:** sha256(action_id, target_id)
- **Ack/Nack:** 2xx; retry/backoff
- **Side-Effects:** gate action if thresholds exceed; request HITL
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When simulation/gating for response impact is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Analyst Portal; E4 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (action_id, helpfulness label, notes)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, action_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** append to governance-reviewed learning queue
- **Observability:** trace_id, mission_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, triaging, selecting_action, preparing, executing, verifying, auditing, contestation_workflow, rolling_back, failed, closed }

- transition(idle -> triaging) on EDR Alert or DetectionEvent
- transition(triaging -> selecting_action) when confidence and severity parsed
- transition(selecting_action -> preparing) when HITL/co-sign evaluated and constraints satisfied
- transition(preparing -> executing) when rollback token created and window open
- transition(executing -> verifying) when vendor API ack received
- transition(verifying -> auditing) when telemetry confirms action
- transition(any -> contestation_workflow) on PolicyDispute or stakeholder_disagreement_score >= 0.5
- transition(any -> rolling_back) when verification fails or TTL expires for isolation
- transition(* -> failed) on timeout or validation error

timeouts: execute_ack<=30 s; verify<=120 s; rollback<=300 s

idempotency_key (ContainmentCommand) = sha256(action_id, host_id, valid_until_floor_60s)

idempotency_key (EDRActionOutcome) = sha256(host_id, action, request_ts_floor_60s)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 EDRActionOutcome	Required	Always	Assurance, audit, and telemetry linkage
OC-2 ContainmentCommand	Conditionally Required	PEP/gateway orchestration or co-sign/HITL policy applies	Safe, governed execution of actions
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Response simulation/gating enabled	Risk-aware decisioning
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- Required: Must be implemented for conformant deployment
- Conditionally Required: Must be implemented when trigger condition is met
- Optional: May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: **IR-4, SI-4, CM-6** (+ internal response standards).
- **HITL required:** host isolation on CrownJewels; actions with model_confidence < theta_low; bulk actions > N per minute.
- **Automatic HITL escalation triggers:** model_confidence < 0.75; model_drift_detected = true; stakeholder_disagreement_score >= 0.5.
- **Manual outside agent:** DFIR deep eradication, OS rebuilds.

SLOs and KPIs [Informative]

- `ExecuteAck_p95` <= 30 s
- `VerifyOutcome_p95` <= 120 s
- `FalselsoationRate_30d` <= 0.25 percent
- `RollbackMTTR_p95` <= 5 min
- `OutcomeEmissionLag_p95` <= 10 s

Outputs index [Informative]

[OC-1 EDRActionOutcome], [OC-2 ContainmentCommand], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E4) [Informative]

Model and training profile [Informative]

`model_id=protect-edr-text-model`; `temperature=0.1`; `max_tokens_out=600`
`prompt_pack_id=edr-response-v1` (playbooks by technique, HITL/co-sign rules, rollback discipline)
RAG: `sources={vendor API docs, outcome history, asset criticality registry, playbooks}`;
`max_docs=10`; `min_similarity=0.78`; citations required
`fine_tuning/adapters: none initially`; eval on action correctness and verification success rate
guardrails: require `rollback_ttl_minutes` for isolation; deny destructive file deletes;
enforce co-sign check when constraint present

Memory and state [Informative]

`working_memory.max_tokens=4k`; `eviction=recency_then_importance`
`episodic_memory: per mission_id journal (alerts, actions, outcomes, approvals)`,
`ttl=365d`
`semantic_memory: namespaces=["playbooks","assets","outcomes","approvals"]`;
`embeddings=text-embedding-sec-v1`; `k=8`
`durable_state_store: event-sourced action ledger`; snapshots hourly
consistency: exactly-once per `action_id` for `ContainmentCommand`; at-least-once for outcomes
idempotency: per Output Contracts

Decision and routing logic [Informative]

- $\text{severity_weight} = \text{map}\{\text{Low}:0.2, \text{Medium}:0.4, \text{High}:0.7, \text{Critical}:1.0\}$
- $\text{cj} = 1$ if "crown_jewel" in `asset_tags` else 0
- $\text{action_priority_score} = 0.45\text{severity_weight} + 0.30\text{confidence} + 0.15\text{cj} + 0.10\text{technique_risk}$
- $\text{isolate_if} = (\text{action_priority_score} \geq 0.75 \text{ and } \text{lateral_movement_signal} = \text{true})$ or $(\text{cj}=1 \text{ and } \text{beaconing}=\text{true})$
- $\text{require_hitl_if} = (\text{cj}=1 \text{ and } \text{isolate_if}=\text{true})$ or $\text{model_confidence} < \text{theta_low}$
- $\text{change_impact_score} = 0.4\text{user_disruption} + 0.3\text{asset_criticality} + 0.3*\text{dependency_risk}$
- $\text{apply_if} = (\text{change_impact_score} < 0.7)$ and (constraints satisfied) and (co-sign present if required)

Model Risk Management [Informative]

`continuous_validation`: daily with adversarial prompts (e.g., misleading recommendations)

`thresholds`: `eval_pass_rate` ≥ 99.5 percent $\rightarrow$ `auto_HITL` if below

`red_team_cycle`: monthly tests for unsafe command generation and missed rollback paths

`rollback_policy`: `eval_drop` ≥ 1.5 percentage points for 48 h $\rightarrow$ revert `model_id`; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: who/what/why; `evidence_refs`; `policy_refs`; hashes; expected vs. observed outcomes

UI/API: expose `classification_label`, `provenance.attestation`, `decision_rationale_url`

`audit_log_format`: JSONL; stable field order; retention per classification and `legal_hold`

Incident Response Integration [Informative]

emit `IRPolicyViolationEvent` (OC-4) if action failed or caused regression; attach `EDRActionOutcome` and error diagnostics

Change Impact Assessment [Informative]

emit `ChangeImpactReport` (OC-5) for isolation/quarantine with potential business disruption; gate by thresholds; request HITL if exceeded

Stakeholder Feedback Loop [Informative]

ingest FeedbackIngestionEvent (OC-6); use in governance-reviewed updates to prompt_pack; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

treat payloads as **C3** when rich endpoint telemetry is present; route evidence_refs to in-region stores; legal_hold=true extends retention and blocks purge

Interfaces (links only) [Informative]

Consumes: EDR Alerts; DetectionEvent

Produces: OC-1 EDRActionOutcome; OC-2 ContainmentCommand; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance or co-sign failure; sandbox execution when attestation missing; blast-radius caps (<= 50 concurrent isolates; <= 200 concurrent kills)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay on past incidents; red-team drills (unsafe actions); drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-vendor concurrency caps; canary for new action types; auto-rollback on failed verification; SBOM + in-toto/SLSA; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (IR-4, SI-4, CM-6); NIST SP 800-61 Rev. 2; NIST SP 800-137; MITRE ATT&CK/D3FEND; CIS Controls v8

MCP-Native Protocol Specification (E4) [Normative]

- **Native Protocol(s) Consumed:** EDR Alerts (REST/Webhook/Stream); DetectionEvent (Kafka/AMQP/REST)
- **Native Protocol(s) Produced:** Vendor containment API calls (kill/quarantine/isolate/de-isolate); EDRActionOutcome (bus); optional ticket updates

- **MCP Context Fields:**
 - **Required:** mission_id; role="EDRResponseAgent"; intent="implement"; constraints including HITL/isolation rules and rollback TTL; policy_refs (IR-4, SI-4, CM-6); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PEPs must verify HITL/co-sign for CrownJewel isolation, valid rollback TTL, provenance attestation, and idempotency before executing actions.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges and EOL.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E5. Phishing Defense Agent

Agent Blueprint [Informative]

Purpose: Filter inbound email, detonate/sandbox suspicious content, auto-block malicious senders/domains/URLs, and emit downstream actions.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Mail Gateway Telemetry (REST/Webhook/SMTP logs + Sandbox verdicts):** message events, header auth results (SPF/DKIM/DMARC), URL rewrites, attachment hashes, detonation outcomes, pipeline policy.
- **IntelIOC (STIX/TAXII):** malicious sender domains, IPs, URLs, attachment hashes, and **COA** tags that prescribe block actions.

Model training / knowledge (what the LLM relies on):

- Style/rubric for **inbox safety**, **false-positive minimization**, **evidence-led blocking**, **TTL-based reversibility**, and **provider allowlist-only** external writes.

- RAG over: mail gateway API docs and policy objects, sandbox vendor behavior ontology, brand-spoof heuristics, DMARC alignment rules, allow/deny provider registry, historical false-positive/true-positive rates. Do not train on raw message bodies; use evidence_refs.
- Guardrails: enforce external_blocklist_write:allowlist_only; restrict providers to providers_allowlist; require ttl_hours for any external block; auto-quarantine must be idempotent per message_id.

Decisions it makes (deterministic + model-assisted):

- **Risk scoring & action selection:** combine detonation verdicts, header auth failures, brand-spoof signals, and intel COAs to choose among {block sender/domain/url/ip, mailbox quarantine/move}.
- **Scope & TTL:** prefer **scoped blocks** (URL or sender) with limited TTL (e.g., 24 h) unless corroborated by multiple signals; widen scope only with high confidence.
- **Provider routing:** publish to external providers **only** if provider ∈ allowlist and evidence meets bar; else local gateway policy only.
- **Rollback plan:** attach TTL and rollback token to every external block; schedule expiration audits.
- **Verification:** confirm enforcement (e.g., gateway policy updated, message moved/quarantined) and emit reports.

Routing / where outputs go:

- **PhishBlockAction** → mail gateways and (optionally) external threat-sharing/blocklist providers (Spamhaus, AbuseCH/URLHaus), per allowlist.
- **MaliciousAttachmentReport** → detection bus and IR data lake; link detonation evidence and COAs.
- **Audit/SIEM** and optional **ticket** updates on every action; HITL requests for high-blast-radius domain blocks.

Automation scope vs. manual/HITL:

- Fully automated: per-message quarantine/move; URL/sender scoped blocks with TTL; detonation orchestration and evidence linking.

- **HITL required:** org-wide sender/domain blocks, blocks affecting partner domains or major brands (DMARC-aligned), bulk retroactive quarantines across many mailboxes.
- Manual outside agent: takedown requests to registrars/hosts, legal outreach, awareness comms.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **Mail Gateway Telemetry (REST/Webhook/SMTP logs + Sandbox)** — message events and detonation outcomes
2. **IntelIOC (STIX/TAXII)** — indicators with COA tags

Example: Consumed Protocol — Mail Gateway Telemetry (message + detonation)

[Informative]

Native payload

```
{
  "event_type": "message_report",
  "message_id": "MSG-2025-08-15-9f2a",
  "timestamp": "2025-08-15T14:44:10Z",
  "sender": {
    "from": "billing@acme-payments.support",
    "envelope_from": "mailer@bad-campaign.org",
    "display_name": "Acme Billing",
    "spf": "fail",
    "dkim": "none",
    "dmarc": "fail"
  },
  "recipients": ["april.ng@example.com"],
  "subject": "Invoice overdue - action required",
```

```

"urls": [{"original": "https://acme-payments.support/secure/login","rewritten":
"http://198.51.100.77/login","category": "phishing"}],

"attachments": [{"filename": "invoice_0725.docm","sha256":
"0f5a1a1b0c1de117f0f4e1d6b7a4a9b9f3921b3cb2f5a1a9a3b0d2e11f99ab55","mimety
pe": "application/vnd.ms-word","size_bytes": 153600}],

"sandbox": {

  "job_id": "sbx-7d12c5a9","engine": "detonation-lab-x","engine_version":
"5.4.2","verdict": "malicious","family": "AgentTesla",

  "behaviors": ["macro_execute","beacon_http_to","drop_file"],

  "ioc": {"dst_ip": "198.51.100.77","dst_domain": "c2.bad-actor.example","http_path":
"/orion/v2/collect"}

},

"pipeline": {"gateway": "secure-mail-gw-X", "policy": "inbound_default"}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e5-mail-1111-2222-3333-4444",
    "thread_id": "uuid-msg-MSG-2025-08-15-9f2a",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "PhishingDefenseAgent",
    "intent": "implement",

    "constraints": ["external_blocklist_write:allowlist_only","providers_allowlist:[spamhaus,
abusech, urlhaus]","ttl_hours:24","auto_quarantine:true"],

    "policy_refs": ["SI-8","SI-4","SC-7"],

    "decision_basis": {"evidence_refs": ["uri://mailgw/events/MSG-2025-08-15-
9f2a","uri://sandbox/jobs/sbx-7d12c5a9"],"confidence": 0.96,"explanation_ref":
"uri://kb/phish/auto-block-rules#detonation-positive"},

```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/protect/phishing-defense-agent",
  "signing_kid": "kid-mail-e5-01",
  "attestation_ref": "uri://slsa/attestations/phishing-defense@sha256:mail01",
  "analysis_engine": {"sandbox_vendor": "detonation-lab-x", "engine_version":
"5.4.2", "job_id": "sbx-7d12c5a9"}
},
"classification": "C3",
"legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — IntelIOC (STIX/TAXII) [Informative]

Native payload

```

{
  "type": "indicator",
  "id": "indicator--a3f20d33-1fcb-4d2c-8514-1a0c6a0e2b41",
  "created": "2025-08-15T13:50:00Z",
  "pattern": "[domain-name:value = 'acme-payments.support' OR url:value MATCHES
'^http://198\\.51\\.100\\.77/login']",
  "labels": ["phishing", "coa:block"],
  "valid_from": "2025-08-15T13:50:00Z",
  "external_references": [
    {"source_name": "URLHaus", "url": "https://urlhaus.abuse.ch/url/1234567/"},
    {"source_name": "Spamhaus", "url":
"https://check.spamhaus.org/listed/198.51.100.77"}
  ]
}

```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e5-intel-5555-6666-7777-8888",
    "thread_id": "uuid-stix-indicator--a3f20d33-1fcb-4d2c-8514-1a0c6a0e2b41",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "PhishingDefenseAgent",
    "intent": "implement",
    "constraints": ["external_blocklist_write:allowlist_only","providers_allowlist:[spamhaus,
abusech, urlhaus]","ttl_hours:24"],
    "policy_refs": ["SI-8","SC-7"],
    "decision_basis": {"evidence_refs": ["uri://taxii/indicators/indicator--a3f20d33-1fcb-
4d2c-8514-1a0c6a0e2b41"],"confidence": 0.9,"explanation_ref": "uri://kb/phish/intel-to-
blocklist"},
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/protect/phishing-defense-agent",
      "signing_kid": "kid-intel-e5-02",
      "attestation_ref": "uri://slsa/attestations/phishing-defense@sha256:intel02",
      "analysis_engine": {"intel_provider": "taxii-feed-prod","feed_version":
"2025.08","partition": "phishing"}
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... as above ... }
}
```

Outputs (native) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **PhishBlockAction:** sender/domain/url/ip block; mailbox move/quarantine (per-message).
- **MaliciousAttachmentReport:** detonation evidence, IoCs, recommended COAs (and any auto-opened tickets).

MCP context (required) [Informative]

mission_id; role="PhishingDefenseAgent"; intent="implement"; constraints including **external blocklist guardrails:** external_blocklist_write:allowlist_only, providers_allowlist:[...], ttl_hours:<n>, auto_quarantine:true; provenance with **analysis_engine info** (sandbox vendor/version/job_id or intel feed metadata), SPIFFE ID, signing KID, attestation.

MCP context (optional) [Informative]

policy_refs (e.g., SI-8, SI-4, SC-7); classification (often C3); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold.

Enforcement note [Informative]

PEPs must verify: provider ∈ providers_allowlist; ttl_hours present for any external write; provenance.attestation and analysis_engine info; idempotency keys; HITL approval for org-wide or partner-brand domain blocks; deny writes when provider not allowlisted.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — adaptive boundary protection with assured provenance.
Related: NIST SP 800-53 Rev. 5 **SI-8, SI-4, SC-7**.

Automation feasibility [Informative]

High for per-message and scoped blocks (URL/sender) with TTL; org-wide domain/IP blocks are HITL-gated.

Output Contracts (merged) [Informative]

OC-1: PhishBlockAction (enforcement update) [Informative]

- **Producer(s):** E5
- **Topic/Path:** https://mailgw.api/v1/blocklist and/or sec.mail.block_action
- **Schema/Format:** **PhishBlockAction@1.1** (action_type ∈ {block_url, block_sender, block_domain, block_ip, move_to_quarantine}; target; scope

{tenant|gateway|org|provider}; ttl_hours; provider_id?; message_ids[]?;
evidence_refs[]; rollback_token; mission_id; trace_id)

- **Classification:** C2 (C3 if message content present)
- **Delivery:** exactly-once per (target, scope, ttl_window)
- **Ordering:** per-target
- **Idempotency-Key:** sha256(action_type, target, scope, ttl_floor_60s)
- **Ack/Nack:** 2xx with action_id; NACK on provider not allowlisted or missing TTL
- **Timeouts/Retry:** ack<=30 s; retry exp-backoff<=5x
- **Side-Effects:** gateway policy updated; optional external provider submission; ticket note appended
- **HITL Token:** required for org-wide domain blocks or partner-brand domains (DMARC-aligned)
- **Observability:** trace_id, mission_id, evidence_refs, decision_basis.confidence, classification_label, provenance.attestation
- **Retention/TTL:** 1 year (actions), 7 years (audit)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PhishBlockAction@1.1 | json_schema_uri=uri://schema/phish-block-action-1.1.json | sha256= | producers=E5 | consumers=MailGW-01, URLRewrite-01, ExtBL-Providers | accepts=1.0–1.2 (1.0 EOL 2026-06-30)

Conformance: Normative.

OC-2: MaliciousAttachmentReport (detonation evidence) [Informative]

- **Producer(s):** E5
- **Topic/Path:** sec.mail.malicious_attachment
- **Schema/Format: MaliciousAttachmentReport@1.0** (message_id, attachment_sha256, sandbox.job_id/vendor/version, verdict, family, observed_behaviors[], extracted_iocs{ip,domain,url,path}, recommended_coas[], evidence_refs[], mission_id, trace_id)
- **Classification:** C3

- **Delivery:** at-least-once
- **Ordering:** per message_id
- **Idempotency-Key:** sha256(message_id, attachment_sha256, sandbox_job_id)
- **Ack/Nack:** 2xx with report_id; retry/backoff on failure
- **Side-Effects:** open ticket if required by policy; enrich intel store
- **HITL Token:** none
- **Observability:** trace_id, mission_id, decision_rationale_url, provenance.attestation
- **Retention/TTL:** 7 years (IR evidence policy)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When sandbox verdict ∈ {malicious, high_risk}

schema_id=MaliciousAttachmentReport@1.0 | json_schema_uri=uri://schema/mal-attachment-report-1.0.json | sha256= | producers=E5 | consumers=IR-DataLake-01, SOAR-01, IntelStore-01

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E5, SecOps/Helpdesk Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0 (action_id or domain/url; rationale; severity; requested_remedy)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-target
- **Idempotency-Key:** sha256(target, dispute_id)
- **Ack/Nack:** case_id≤30 s; retry/backoff
- **Side-Effects:** freeze related broad blocks pending review
- **HITL Token:** required when severity ≥ high
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (IR integration) [Informative, optional]

- **Producer(s):** E5
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (e.g., block failed or caused mail outage)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, action_id_or_target)
- **Ack/Nack:** SIEM/CaseID<=30 s; retry/backoff
- **Side-Effects:** SOAR case open; attach PhishBlockAction and MaliciousAttachmentReport
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (email hygiene impact) [Informative, optional]

- **Producer(s):** E5 (pre-enforcement)
- **Topic/Path:** sec.mail.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (estimated affected users, historical benign traffic to target, brand-spoof likelihood, dependency hits, rollback plan)
- **Classification:** C1–C2

- **Delivery/Ordering:** at-least-once; per-proposal_id
- **Idempotency-Key:** sha256(proposal_id, target, ttl_floor_60s)
- **Ack/Nack:** 2xx; retry/backoff
- **Side-Effects:** gate broad blocks; request HITL if thresholds exceeded
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When simulation/gating for broad blocks is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Helpdesk/End-User Portal; E5 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (message_id or target; label={helpful|neutral|harmful}; notes)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, target_or_message_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** queue for governance-reviewed learning; never auto-train on message bodies
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_message, detonating, scoring, proposing_action, simulating_impact, enforcing, verifying, auditing, contestation_workflow, rolling_back, failed, closed }

- transition(idle -> ingesting_message) on message_report or intel indicator
- transition(ingesting_message -> detonating) when attachment or risky URL present
- transition(detonating -> scoring) when verdict ready
- transition(scoring -> proposing_action) when evidence aggregated
- transition(proposing_action -> simulating_impact) when scope $\geq$ domain or provider write requested
- transition(simulating_impact -> enforcing) when thresholds pass or HITL satisfied
- transition(enforcing -> verifying) when gateway/provider ACK received
- transition(verifying -> auditing) when enforcement observed (e.g., message quarantined)
- transition(any -> contestation_workflow) on PolicyDispute or stakeholder_disagreement_score $\geq$ 0.5
- transition(any -> rolling_back) when TTL expires or regression detected
- transition(* -> failed) on timeout/validation error

timeouts: detonation $\leq$ 5 min; provider_ack $\leq$ 30 s; verification $\leq$ 120 s

idempotency_key (PhishBlockAction) = sha256(action_type, target, scope, ttl_floor_60s)

idempotency_key (MaliciousAttachmentReport) = sha256(message_id, attachment_sha256, sandbox_job_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PhishBlockAction	Required	Always	Core phishing enforcement

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-2 MaliciousAttachmentReport	Conditionally Required	Sandbox verdict malicious/high_risk	DFIR evidence & intel enrichment
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Simulation/gating for broad blocks enabled	Risk-aware promotion
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

Required = must implement; Conditionally Required = must implement when condition holds; Optional = may implement.

Policies and HITL gates [Informative]

- policy_refs: **SI-8, SI-4, SC-7** (+ internal mail hygiene standards).
- **HITL required:** org-wide domain/IP blocks; partner/brand domains with DMARC alignment; bulk quarantine across many mailboxes; provider writes when impact score $\geq$ threshold.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score $\geq$ 0.5.
- **Manual outside agent:** legal takedowns, comms to users/partners.

SLOs and KPIs [Informative]

- DetonationVerdictLag_p95 $\leq$ 5 min
- BlockActionAck_p95 $\leq$ 30 s
- QuarantineVerify_p95 $\leq$ 120 s

- FalsePositiveBlockRate_30d <= 0.1 percent
- BlockRollbackMTTR_p95 <= 10 min

Outputs index [Informative]

[OC-1 PhishBlockAction], [OC-2 MaliciousAttachmentReport], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E5) [Informative]

Model and training profile [Informative]

model_id=protect-mail-text-model; temperature=0.1; max_tokens_out=700
 prompt_pack_id=phish-defense-v1 (header auth rubric, brand-spoof rules, sandbox behavior mapping, provider allowlist gates)
 RAG: sources={mail gw policy/API, sandbox ontology, provider registry, FP/TP history}; max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval on action correctness and FP control
 guardrails: enforce external_blocklist_write:allowlist_only; require ttl_hours; deny destructive mailbox purge; scope escalation requires HITL.

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (messages, detonation jobs, actions, rollbacks), ttl=365d
 semantic_memory: namespaces=["mail-policy","sandbox","providers","fp-history"]; embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced action ledger; daily snapshots
 consistency: exactly-once per (target,scope,ttl_window) for PhishBlockAction; at-least-once for reports
 idempotency: per Output Contracts

Decision and routing logic [Informative]

- features: f1=detonation_score, f2=header_auth_fail (0/1), f3=brand_spoof_score, f4=intel_coa (0/1), f5=historical_fp_rate_target
- $\text{phish_risk} = 0.45f1 + 0.20f2 + 0.20f3 + 0.10f4 - 0.05f5$
- $\text{impact_score} = 0.5\text{estimated_users_affected} + 0.3\text{brand_partner_likelihood} + 0.2\text{dependency_risk}$

- `apply_block_if`: `phish_risk >= 0.65` and `impact_score < 0.7` and `provider ∈ allowlist` and `ttr_hours ≥ min_ttr`
- `require_hitl_if`: `impact_score ≥ 0.7` or `target ∈ {partner_brand_domain}`
- `quarantine_if`: `phish_risk ≥ 0.55` and `detonation verdict malicious/high_risk`

Model Risk Management [Informative]

`continuous_validation`: daily goldens + adversarial brand-spoof and benign marketing samples

`thresholds`: `eval_pass_rate >= 99.5` percent → `auto_HITL` if below

`red_team_cycle`: monthly (false-positive pressure tests, provider abuse scenarios)

`rollback_policy`: `eval_drop ≥ 1.5` percentage points for 48 h → revert `model_id`; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: header auth, sandbox evidence, intel refs, risk/impact, chosen action, TTL/rollback

UI/API: expose `classification_label`, `provenance.attestation`, `analysis_engine` info, `decision_rationale_url`

`audit_log_format`: JSONL; stable field order; retention per classification and `legal_hold`

Incident Response Integration [Informative]

emit `IRPolicyViolationEvent` (OC-4) on enforcement failure or outage; attach `PhishBlockAction` and `MaliciousAttachmentReport`; open SOAR case

Change Impact Assessment [Informative]

emit `ChangeImpactReport` (OC-5) for domain/IP blocks; gate promotion; request HITL if thresholds exceeded

Stakeholder Feedback Loop [Informative]

ingest `FeedbackIngestionEvent` (OC-6) from helpdesk/end-users; governance-reviewed updates to `prompt_pack`; never auto-train on message bodies

Data Sovereignty and Legal Hold [Informative]

treat payloads as **C3** when message content present; route `evidence_refs` to in-region stores; `legal_hold=true` extends retention and blocks purge

Interfaces (links only) [Informative]

Consumes: Mail Gateway Telemetry; IntelIOC (STIX/TAXII)

Produces: OC-1 PhishBlockAction; OC-2 MaliciousAttachmentReport; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provider allowlist violation or missing TTL; sandbox mode when attestation missing; blast-radius caps (≤ 1000 URL blocks/day; ≤ 50 domain/IP blocks/day; bulk mailbox quarantine capped at ≤ 200 messages/minute)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay on historical mail streams; FP guardrail tests; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-provider concurrency caps; canary for external provider writes; auto-rollback on FP spike; SBOM + in-toto/SLSA; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-8, SI-4, SC-7); NIST SP 800-61 Rev. 2; NIST SP 800-137; MITRE ATT&CK/D3FEND; CIS Controls v8

MCP-Native Protocol Specification (E5) [Normative]

- **Native Protocol(s) Consumed:** Mail Gateway Telemetry (REST/Webhook/SMTP logs + Sandbox); IntelIOC (STIX/TAXII)
- **Native Protocol(s) Produced:** PhishBlockAction (gateway/external providers) and MaliciousAttachmentReport; audit events to SIEM/SOAR; optional ticket updates
- **MCP Context Fields:**
 - **Required:** mission_id; role="PhishingDefenseAgent"; intent="implement"; constraints including external_blocklist_write:allowlist_only, providers_allowlist:[...], ttl_hours:<n>, auto_quarantine:true; provenance with analysis_engine info, SPIFFE ID, signing KID, attestation
 - **Optional:** policy_refs; classification; decision_basis; legal_hold

- **Enforcement Note:** PEPs must verify provider allowlist membership, TTL presence, provenance/attestation, idempotency keys, and HITL approval for high-impact blocks before enforcement.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges and EOL.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `analysis_engine` metadata, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E6. Cloud Security Agent

Agent Blueprint [Informative]

Purpose: Enforce and remediate CSPM/CWPP/CIEM findings across cloud accounts/projects and Kubernetes; react to drift; apply guardrails (policy-as-code) with auditable changes.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Cloud Posture Findings (CSPM REST/Events):** normalized misconfig/vuln findings (e.g., AWS Security Hub, Azure Defender for Cloud, GCP Security Command Center) with resource, control, severity, status, evidence, and recommendations.
- **Drift Alerts (Config/CloudTrail/K8s Admission audit):** configuration changes diverging from baselines or IaC (e.g., SG widened to 0.0.0.0/0, K8s Admission exception, org policy override).

Model training / knowledge (what the LLM relies on):

- Policy-as-code rubrics (CIS Benchmarks, internal CM-6 hardening rules, org guardrail catalog), change windows, approver matrices.
- RAG over: IaC repo history, change tickets, prior remediations and rollbacks, provider API semantics and limits, exception registry, data residency map. Do not train on cloud logs with secrets; use `evidence_refs`.

- **Guardrails:** enforce region and data residency constraints; deny destructive actions without rollback plan; restrict scope to resource/account in mission; require CAB/HITL for high-blast-radius changes.

Decisions it makes (deterministic + model-assisted):

- **Prioritization:** compute fix_priority_score from severity, data_class, exposure, exploitability, and blast_radius.
- **Mode selection:** choose **CloudFix** (direct remediation) vs **GuardrailEnforcement** (preventive policy) vs **Advisory-only** when privileges or impact thresholds disallow auto-fix.
- **Rollback planning:** create change set with idempotent plan, pre-checks, post-verification probes, and rollback token.
- **Exception handling:** detect business-approved exceptions; emit ChangeImpactReport and seek HITL when thresholds exceeded.

Routing / where outputs go:

- **CloudFix** → provider-native APIs (AWS, Azure, GCP, K8s) through PEP or orchestrator gateway.
- **GuardrailEnforcement** → policy engines (AWS SCPs, Azure Policies, GCP Org Policies, OPA/Gatekeeper, Kyverno).
- **Audit** → SIEM/SOAR and change records; tickets/comments updated with outcome and evidence.

Automation scope vs. manual/HITL:

- **Fully automated:** low-risk remediations with known-safe playbooks (e.g., enable S3 Block Public Access; remove 0.0.0.0/0 on RDP and add bastion SG; rotate stale access key).
- **HITL required:** org-level guardrails (SCPs), changes impacting production networking, breaking changes on CrownJewel workloads, region moves, bulk multi-account remediations.
- **Manual outside agent:** contractual data-locality waivers, re-architecture tasks, exception policy issuance.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **Cloud Posture Findings (CSPM REST/Events)** — normalized misconfiguration/vuln findings
2. **Drift Alerts (Config/CloudTrail/K8s Admission)** — divergence from baselines/IaC

Example: Consumed Protocol — Cloud Posture Findings [Informative]

Native payload

```
{
  "finding_id": "CSPM-2025-08-15-0041",
  "provider": "security_hub",
  "account_id": "123456789012",
  "resource": {"type": "AWS::S3::Bucket", "id": "arn:aws:s3:::payments-logs", "region": "us-east-1", "tags": {"data_class": "PCI"}},
  "control": {"id": "CIS-3.1", "title": "S3 bucket should block public access", "severity": "High"},
  "status": "FAILED",
  "evidence": {"public_access": true, "block_public_acls": false, "block_public_policy": false},
  "recommendation": "Enable S3 Block Public Access and restrict bucket policy",
  "first_seen": "2025-08-15T13:55:00Z",
  "last_seen": "2025-08-15T14:05:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e6-cspm-1111-2222-3333-4444",
    "thread_id": "uuid-finding-CSPM-2025-08-15-0041",
  }
}
```

```

"task_id": "uuid-a1b2-c3d4-e5f6-7788",
"role": "CloudSecurityAgent",
"intent": "implement",
"constraints": ["region:us-east-1","data_residency:US-
only","sla_days:3","change_window:offhours"],
"policy_refs": ["CM-6","SC-7","SI-2","CIS-Cloud-Foundational#3.1"],
"decision_basis": {"evidence_refs": ["uri://cspm/findings/CSPM-2025-08-15-
0041"],"confidence": 0.97,"explanation_ref": "uri://kb/cloud/s3-public-access-
remediation"},
"provenance": {"producer_spiffe": "spiffe://enterprise/protect/cloud-security-
agent","signing_kid": "kid-cspm-e6-01","attestation_ref": "uri://slsa/attestations/cloud-
security@sha256:cspm01"},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — Drift Alerts [Informative]

Native payload

```

{
  "alert_id": "DRIFT-2025-08-15-021",
  "detected_by": "cloud_config",
  "resource": {"type": "AWS::EC2::SecurityGroup","id": "sg-
0abc123def4567890","region": "us-east-1"},
  "baseline_ref": "git://iac/security-groups.tf@7f3e1d2",
  "change": {"property": "ingress","path": "[0].cidr","previous": "10.20.0.0/16","current":
"0.0.0.0/0","port": "3389/tcp"},
  "ts": "2025-08-15T14:12:22Z",
  "actor": "i-automation@ci",

```

```

    "risk": "High"
  }
  MCP-wrapped payload
  {
    "mcp_context": {
      "mcp_version": "0.9",
      "mission_id": "uuid-e6-drift-5555-6666-7777-8888",
      "thread_id": "uuid-drift-DRIFT-2025-08-15-021",
      "task_id": "uuid-99aa-bbcc-ddee-ff00",
      "role": "CloudSecurityAgent",
      "intent": "implement",
      "constraints": ["region:us-east-1","data_residency:US-
only","sla_days:3","change_window:offhours"],
      "policy_refs": ["CM-6","SC-7","AC-4"],
      "decision_basis": {"evidence_refs": ["uri://config/drift/DRIFT-2025-08-15-
021","git://iac/security-groups.tf@7f3e1d2"],"confidence": 0.95,"explanation_ref":
"uri://kb/cloud/sg-open-rdp-remediation"},
      "provenance": {"producer_spiffe":"spiffe://enterprise/protect/cloud-security-
agent","signing_kid":"kid-drift-e6-02","attestation_ref":"uri://slsa/attestations/cloud-
security@sha256:drift02"},
      "classification": "C2",
      "legal_hold": true
    },
    "native_payload": { ... as above ... }
  }

```

Outputs (native) [Informative]

- **CloudFix:** targeted provider operations to correct misconfigurations (e.g., enable S3 Block Public Access; tighten SG; rotate key; disable public VM IP; revoke risky KMS grants).

- **GuardrailEnforcement:** push or update preventive policies (SCPs, Azure Policies, GCP Org Policies, OPA/Gatekeeper, Kyverno).

MCP context (required) [Informative]

mission_id; role="CloudSecurityAgent"; intent="implement"; constraints including region:<name>, data_residency:<policy>, sla_days:<n>, change_window:<rule>; policy_refs (CM-6, SC-7, SI-2, CIS Cloud); provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

classification (C1–C2 typical); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold.

Enforcement note [Informative]

PEPs must verify: region and data_residency constraints, change_window open, valid provenance.attestation, idempotency, and where configured **co-signature from A1 Governance Policy Agent** for org-level guardrails or high-blast-radius changes.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — sustain resilience via enforced guardrails and corrective actions; also maps to NIST SP 800-53 CM-6, SC-7, SI-2 and CIS Cloud controls.

Automation feasibility [Informative]

High: safe, scoped remediations and guardrail pushes are fully automatable; HITL for high-impact/global policy changes.

Output Contracts (merged) [Informative]

OC-1: CloudFix (remediation action) [Informative]

- **Producer(s):** E6
- **Topic/Path:** sec.cloud.fix (bus) and provider-native endpoints (e.g., aws:api, azure:arm, gcp:crm, k8s:api)
- **Schema/Format: CloudFix@1.2** (provider, account/project, resource_type, resource_id, region, change_set_hash, operations[], pre_checks[], post_checks[], rollback_token, mission_id, trace_id, policy_refs, evidence_refs[], expected_state)
- **Classification:** C2

- **Delivery:** exactly-once per (resource_id, change_set_hash)
- **Ordering:** per-resource
- **Idempotency-Key:** sha256(provider, resource_id, change_set_hash)
- **Ack/Nack:** provider ACK with change_id; NACK on constraint violation (region, residency, window)
- **Timeouts/Retry:** ack<=60 s; verify<=300 s; exp-backoff<=5x
- **Side-Effects:** update ticket; append to audit journal; tag resource with remediation metadata
- **HITL Token:** required when blast_radius >= threshold or resource tagged CrownJewel
- **Observability:** trace_id, mission_id, decision_basis.confidence, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-1) [Normative]

Requirement Level: Conditionally Required

Condition: When auto-remediation is enabled or playbook allows direct fix for the finding

schema_id=CloudFix@1.2 | json_schema_uri=uri://schema/cloud-fix-1.2.json | sha256= | producers=E6 | consumers=Cloud-PEP-01, SOAR-01 | accepts=1.0–1.2

Conformance: Normative when condition is met.

OC-2: GuardrailEnforcement (policy-as-code push) [Informative]

- **Producer(s):** E6
- **Topic/Path:** sec.cloud.guardrail and policy engines (SCPs, Azure Policy, GCP Org Policy, OPA/Gatekeeper, Kyverno)
- **Schema/Format:** **GuardrailEnforcement@1.1** (scope {org|folder|subscription|account|project|namespace}, engine, policy_id, version, change_set_hash, mode {audit|enforce|dryrun}, exceptions[], cosign_refs[], mission_id, trace_id, policy_refs, evidence_refs[])
- **Classification:** C1–C2
- **Delivery:** at-least-once

- **Ordering:** per-policy_id
- **Idempotency-Key:** sha256(scope, engine, policy_id, version, change_set_hash)
- **Ack/Nack:** engine ACK with policy_version; retry/backoff; NACK without co-sign when required
- **Timeouts/Retry:** ack<=60 s; propagation_check<=30 min
- **Side-Effects:** policy versioned; exception list reconciled; notify approvers
- **HITL Token:** required for org-level scope or deny-by-default policies
- **Observability:** trace_id, mission_id, cosign_refs, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=GuardrailEnforcement@1.1 | json_schema_uri=uri://schema/guardrail-enforcement-1.1.json | sha256= | producers=E6 | consumers=PolicyEngines, Cloud-PEP-01 | accepts=1.0–1.1

Conformance: Normative.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E6, Cloud Owners Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0 (policy_id or change_id, rationale, severity, requested_remedy, decision_rationale_url)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-policy_id
- **Idempotency-Key:** sha256(policy_id_or_change_id, dispute_id)
- **Ack/Nack:** case_id<=30 s; retry/backoff
- **Side-Effects:** freeze promotion to enforce mode pending review
- **HITL Token:** required when severity >= high
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (IR integration) [Informative, optional]

- **Producer(s):** E6
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (remediation failed or caused outage; guardrail misapplied)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, change_id)
- **Ack/Nack:** SIEM/CaseID<=30 s; retry/backoff
- **Side-Effects:** open SOAR case; attach CloudFix or GuardrailEnforcement records
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (risk and blast-radius analysis) [Informative, optional]

- **Producer(s):** E6
- **Topic/Path:** sec.cloud.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (affected services, dependencies, rollback plan, users impacted, exception hits)
- **Classification:** C1–C2
- **Delivery/Ordering:** at-least-once; per-proposal_id

- **Idempotency-Key:** sha256(proposal_id, change_set_hash)
- **Ack/Nack:** 2xx; retry/backoff
- **Side-Effects:** gate promotion to enforce; request HITL if thresholds exceeded
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When simulation/gating is enabled or blast_radius >= threshold

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Cloud Owners Portal; E6 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (change_id or policy_id; label={helpful|neutral|harmful}; notes)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, change_or_policy_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** queue for governance-reviewed learning
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, triaging_finding, assessing, proposing_fix, simulating_impact, enforcing_fix, pushing_guardrail, verifying, auditing, contestation_workflow, rolling_back, failed, closed }

- transition(idle -> triaging_finding) on CSPM finding or Drift Alert
- transition(triaging_finding -> assessing) after enrichment (tags, data_class, ownership)
- transition(assessing -> proposing_fix) when fix_priority_score computed
- transition(proposing_fix -> simulating_impact) when scope is multi-resource or org-level
- transition(simulating_impact -> enforcing_fix) when thresholds pass or HITL satisfied
- transition(proposing_fix -> pushing_guardrail) when preventive policy chosen
- transition(enforcing_fix|pushing_guardrail -> verifying) on provider ACK
- transition(verifying -> auditing) when post-checks succeed
- transition(any -> contestation_workflow) on PolicyDispute or stakeholder_disagreement_score >= 0.5
- transition(any -> rolling_back) when post-check fails or regression detected
- transition(* -> failed) on timeout or validation error

timeouts: provider_ack<=60 s; post_verify<=300 s; rollback<=600 s

idempotency_key (CloudFix) = sha256(provider, resource_id, change_set_hash)

idempotency_key (GuardrailEnforcement) = sha256(scope, engine, policy_id, version, change_set_hash)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 CloudFix	Conditionally Required	Auto-remediation enabled or playbook allows direct fix	Exposure reduction via fast remediation

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-2 GuardrailEnforcement	Required	Always	Preventive policy enforcement
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Simulation/gating enabled or blast_radius >= threshold	Risk-aware promotion
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

Required = must implement; Conditionally Required = must implement when condition holds; Optional = may implement.

Policies and HITL gates [Informative]

- policy_refs: **CM-6, SC-7, SI-2, CIS Cloud** (+ internal guardrails).
- **HITL required:** org-level guardrails (SCPs, deny-by-default), network policy affecting production egress, changes on CrownJewel-tagged resources, cross-account bulk fixes.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; model_drift_detected = true; stakeholder_disagreement_score >= 0.5; impact_score >= 0.7.
- **Manual outside agent:** architecture migrations, exception issuance.

SLOs and KPIs [Informative]

- ProviderAck_p95 <= 60 s
- PostVerify_p95 <= 300 s
- DriftRevert_MTTR_p95 <= 15 min

- MisconfigExposure_Hours (High/Critical) <= 24 h rolling average
- RemediationRollbackRate_30d <= 2 percent

Outputs index [Informative]

[OC-1 CloudFix], [OC-2 GuardrailEnforcement], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E6) [Informative]

Model and training profile [Informative]

model_id=protect-cloud-text-model; temperature=0.1; max_tokens_out=800
 prompt_pack_id=cloud-security-v1 (CIS hardening, guardrail catalog, change-window rules, CAB/HITL gates)

RAG: sources={IaC repo, policy registry, provider API docs, prior fixes/rollbacks, exception registry}; max_docs=12; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval on fix correctness and rollback success
 guardrails: enforce region and data_residency; require rollback plan; deny scope escalation beyond mission accounts

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (findings, fixes, guardrails, verifications), ttl=365d
 semantic_memory: namespaces=["iac","guardrails","fix-history","exceptions"];
 embeddings=text-embedding-sec-v1; k=10
 durable_state_store: event-sourced change ledger; snapshots per 1 h
 consistency: exactly-once per (resource_id, change_set_hash) for CloudFix; at-least-once for guardrail pushes
 idempotency: per Output Contracts

Decision and routing logic [Informative]

- severity_map = {"Informational":0.1,"Low":0.25,"Medium":0.5,"High":0.75,"Critical":1.0}
- data_class_weight = {"PCI":1.0,"PHI":0.9,"PII":0.8,"Internal":0.5,"Public":0.2}
- exposure = 1 if internet_exposed else 0.3
- exploitability = 1 if CVE_exploited_in_the_wild else 0.5

- `blast_radius` in `[0,1]` from dependency graph size and account scope
- $\text{fix_priority_score} = 0.35\text{severity_map} + 0.25\text{data_class_weight} + 0.2\text{exposure} + 0.1\text{exploitability} + 0.1*\text{blast_radius}$
- $\text{impact_score} = 0.5\text{service_disruption} + 0.3\text{dependency_hits} + 0.2*\text{exception_overlap}$
- choose CloudFix if `fix_priority_score` ≥ 0.65 and `impact_score` < 0.7 and constraints satisfied; else GuardrailEnforcement or Advisory
- `require_hitl_if`: `impact_score` ≥ 0.7 or scope in `{"org","folder"}` or `CrownJewel=true`

Model Risk Management [Informative]

`continuous_validation`: daily goldens and adversarial change sets (e.g., destructive deletes)

thresholds: `eval_pass_rate` ≥ 99.5 percent $\rightarrow$ auto_HITL if below

`red_team_cycle`: monthly ATT&CK-influenced infra changes and policy bypass attempts

`rollback_policy`: `eval_drop` ≥ 1.5 percentage points for 48 h $\rightarrow$ revert `model_id`; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: who/what/why, `evidence_refs`, `policy_refs`, hashes, expected vs observed state

UI/API: expose `classification_label`, `provenance.attestation`, `decision_rationale_url`

`audit_log_format`: JSONL; stable field order; retention per classification and `legal_hold`

Incident Response Integration [Informative]

emit `IRPolicyViolationEvent` (OC-4) on failed fix or policy causing outage; attach CloudFix/GuardrailEnforcement records and diagnostics

Change Impact Assessment [Informative]

emit `ChangeImpactReport` (OC-5) for org-level guardrails or multi-account fixes; gate promotion; request HITL if thresholds exceeded

Stakeholder Feedback Loop [Informative]

ingest `FeedbackIngestionEvent` (OC-6); feed governance-reviewed updates to `prompt_pack`; never auto-train on provider logs with secrets

Data Sovereignty and Legal Hold [Informative]

enforce data_residency:US-only (or org policy) at ingress and egress; legal_hold=true extends retention and blocks purge for related changes

Interfaces (links only) [Informative]

Consumes: Cloud Posture Findings (CSPM); Drift Alerts (Config/CloudTrail/K8s Admission)

Produces: OC-1 CloudFix; OC-2 GuardrailEnforcement; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance or co-sign failure; sandbox mode on missing attestation; blast-radius caps (≤ 100 concurrent fixes; ≤ 10 org-scope guardrail changes per day)

Testing and validation [Informative]

contract tests derived from Schema Capsules; offline replay of historical findings; negative tests (deny destructive ops); drift checks and rollback drills

Deployment and lifecycle [Informative]

HPA on queue depth; per-provider concurrency caps; canary on new guardrails; auto-rollback on verification failure; SBOM + in-toto/SLSA; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-6, SC-7, SI-2); NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST SP 800-207; CIS Controls v8; CIS Cloud Benchmarks; MITRE ATT&CK/D3FEND; OPA/Gatekeeper; Kyverno

MCP-Native Protocol Specification (E6) [Normative]

- **Native Protocol(s) Consumed:** Cloud Posture Findings (CSPM REST/Events); Drift Alerts (Config/CloudTrail/K8s Admission)
- **Native Protocol(s) Produced:** CloudFix (provider operations); GuardrailEnforcement (policy-as-code); audit events to SIEM/SOAR
- **MCP Context Fields:**
 - **Required:** mission_id; role="CloudSecurityAgent"; intent="implement"; constraints including region, data_residency, sla_days, change_window; policy_refs; provenance (SPIFFE ID, signing KID, attestation)

- **Optional:** classification; decision_basis; legal_hold
- **Enforcement Note:** PEPs must verify region/data_residency, open change window, provenance attestation, idempotency keys, and required co-sign/HITL for org-level or high-impact changes before execution.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges and EOL.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E7. Baseline Enforcement Agent

Agent Blueprint [Informative]

Purpose: Apply secure configurations to infrastructure and services using approved enforcement plans; push idempotent changes (infra-as-code or config tools) and report **EnforcementResult**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **EnforcementPlans (REST/Git/Artifact store):** change tickets, approved windows, target selectors (labels, explicit assets), engine steps (Ansible/Puppet/Chef/DSC/K8s/Network), verification checks, optional PR references.
- **RCAFindings (REST/Object Storage):** incident-driven hardening and containment steps to fold back into baselines.

Model training / knowledge (what the LLM relies on):

- Rubrics for baseline hardening (CM-6, CM-2, RA-5), rollback requirements, change windows, canary rules, environment blast-radius limits.
- RAG over: baseline repos (history and PRs), prior EnforcementResult logs, approved playbook library, exception register, RCA-to-baseline mappings. No training on regulated artifacts; use evidence_refs.

- Guardrails: enforce `requires_pr:true` when set; deny out-of-window enforcement; restrict engines and playbooks to allowlist; require rollback token for multi-host changes.

Decisions it makes (deterministic + model-assisted):

- **Plan validation:** check approvals, window, scope selectors resolve to expected targets; verify engine compatibility and idempotency flags.
- **Rollout mode:** choose canary percentage and batch size; compute **enforcement_risk_score**; decide **enforce vs. stage** vs. **HITL**.
- **Rollback policy:** pre-generate rollback steps per engine; hold rollback token with TTL.
- **Codification path:** if plan originated from RCA or ad-hoc, decide whether to propose PR to baseline repo.

Routing / where outputs go:

- **ConfigSet** → engines/gateways (gRPC/HTTPS/CLI proxy) that talk to Ansible/Puppet/Chef/DSC/K8s/Network controllers.
- **EnforcementResult** → message bus (Kafka/AMQP/REST) and ticket comments; SIEM audit.
- Optional **PR updates** → baseline Git repos (linked in EnforcementResult).

Automation scope vs. manual/HITL:

- Fully automated: canary and broad rollout for low-impact changes with successful simulation and passing checks.
- **HITL required:** production changes on CrownJewel-tagged assets, engine steps that modify auth paths, network-wide ACL templates, cross-namespace K8s policies.
- Manual outside agent: refactoring baselines, introducing new engines, accepting long-term exceptions.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **EnforcementPlans (REST/Git/Artifact store)** — approved, idempotent enforcement steps and verification

2. RCAFindings (REST/Object Storage) — incident-derived hardening actions

Example: Consumed Protocol — EnforcementPlans [Informative]

Native payload

```
{
  "plan_id": "ENF-2025-08-15-017",
  "source": "BaselineComplianceAgent",
  "approval": {
    "change_ticket": "CHG0054421",
    "approvals": ["sec.cab", "payments.sre"],
    "window": "2025-08-16T01:00:00Z/2025-08-16T03:00:00Z"
  },
  "scope": {
    "selectors": [
      {"labels": {"env": "prod", "app": "payments", "tier": "web"}},
      {"assets": ["srv-001", "srv-017"]}
    ],
    "region": "us-east-1"
  },
  "steps": [
    {
      "engine": "ansible",
      "idempotent": true,
      "playbook_uri": "git://baselines/linux/ssh.yml@v3.2.1",
      "vars": {"sshd_PermitRootLogin": "no", "sshd_LogLevel": "VERBOSE"},
      "canary": {"percent": 10}
    },
    {
```

```

    "engine": "dsc",
    "idempotent": true,
    "module_uri": "git://baselines/windows/auditpol.ps1@v1.9.0",
    "vars": {"ProcessCreation": "Enabled"},
    "targets": ["WIN-SRV-02"]
  },
  {
    "engine": "k8s",
    "kind": "K8sManifest",
    "manifest_uri": "git://baselines/k8s/psa-restricted.yaml@v1.4.0",
    "namespace": "payments"
  }
],
"verification": {
  "post_checks": ["ssh_config_ok", "auditpol_ok", "psa_enforced"],
  "re_scan": {"vuln_platform": "tenable", "ttl_hours": 24}
},
"pr_refs": ["https://git.example.com/sec/baselines/pulls/842"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-e7-plan-1111-2222-3333-4444",
    "thread_id": "uuid-enf-plan-ENF-2025-08-15-017",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
  }
}

```

```
"role": "BaselineEnforcementAgent",
"intent": "implement",
"constraints": [
  "requires_pr:true",
  "change_window:offhours",
  "canary_required:true",
  "hitl_required:prod",
  "rollback_ttl_minutes:120"
],
"policy_refs": ["CM-6", "CM-2", "RA-5"],
"decision_basis": {
  "evidence_refs": [
    "uri://plans/ENF-2025-08-15-017",
    "git://baselines/linux/ssh.yml@v3.2.1",
    "git://baselines/k8s/psa-restricted.yaml@v1.4.0",
    "https://git.example.com/sec/baselines/pulls/842"
  ],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/enforcement/plan-execution-flow"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/protect/baseline-enforcement-agent",
  "signing_kid": "kid-plan-e7-01",
  "attestation_ref": "uri://slsa/attestations/baseline-enforcement@sha256:plan01"
},
"classification": "C2",
```

```
    "legal_hold": false
  },
  "native_payload": { ... as above ... }
}
```

Example: Consumed Protocol — RCAFindings [Informative]

Native payload

```
{
  "rca_id": "RCA-2025-0815-0073",
  "incident_id": "INC-45920",
  "observed_gaps": [
    "SSH PermitRootLogin enabled on prod web nodes",
    "Kubernetes namespace payments lacks PSA-restricted"
  ],
  "hardening_actions": [
    {"engine": "ansible", "action": "set_sshd", "vars": {"PermitRootLogin": "no"}},
    {"engine": "k8s", "action": "apply_manifest", "manifest_uri": "git://baselines/k8s/psa-restricted.yaml@v1.4.0"}
  ],
  "priority": "High",
  "evidence_uris": [
    "s3://dfir/INC-45920/host/ssh-configs",
    "s3://dfir/INC-45920/k8s/ns-scan.json"
  ]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
```

```
"mcp_version": "0.9",
"mission_id": "uuid-e7-rca-5555-6666-7777-8888",
"thread_id": "uuid-rca-RCA-2025-0815-0073",
"task_id": "uuid-99aa-bbcc-ddee-ff00",
"role": "BaselineEnforcementAgent",
"intent": "implement",
"constraints": [
  "requires_pr:true",
  "change_window:offhours",
  "canary_required:true",
  "rollback_ttl_minutes:120"
],
"policy_refs": ["CM-6", "CP-2", "IR-4"],
"decision_basis": {
  "evidence_refs": [
    "uri://rca/RCA-2025-0815-0073",
    "s3://dfir/INC-45920/host/ssh-configs",
    "s3://dfir/INC-45920/k8s/ns-scan.json"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/enforcement/rca-to-baseline"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/protect/baseline-enforcement-agent",
  "signing_kid": "kid-rca-e7-02",
  "attestation_ref": "uri://slsa/attestations/baseline-enforcement@sha256:rca02"
```

```

    },
    "classification": "C2",
    "legal_hold": true
  },
  "native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **ConfigSet:** idempotent enforcement executions via engines (Ansible/Puppet/Chef/DSC/K8s/Network).
- **EnforcementResult:** final status per step with verification evidence and re-scan outcomes.

MCP context (required) [Informative]

mission_id; role="BaselineEnforcementAgent"; intent="implement"; constraints including requires_pr:true|false, change_window:<rule>, canary_required:true|false, hitl_required:<scope>, rollback_ttl_minutes:<n>; policy_refs; provenance (SPIFFE ID, signing KID, attestation).

MCP context (optional) [Informative]

classification (C1–C2; C3 if user/device data present); decision_basis; legal_hold.

Enforcement note [Informative]

PEPs must verify open change window, co-sign/HITL tokens when required, provenance.attestation, idempotency keys, and rollback token validity before executing **ConfigSet**.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — resilient configurations with rollback assurance; aligns with NIST SP 800-53 CM-6, CM-2, RA-5.

Automation feasibility [Informative]

High: canary→progressive rollout with automated verification and rollback; HITL gates for high-impact scopes.

Output Contracts (merged) [Informative]

OC-1: ConfigSet (idempotent enforcement request) [Informative]

- **Producer(s):** E7
- **Topic/Path:** sec.enforcement.configset and engine gateways (ansible:gRPC, k8s:https, network:cli-proxy)
- **Schema/Format: ConfigSet@1.3** (plan_id, change_set_hash, steps[], engine, artifact_uri, vars, selectors, explicit_targets[], canary.percent, window, rollback_token, mission_id, trace_id, policy_refs, evidence_refs[], expected_state, idempotent=true)
- **Classification:** C2
- **Delivery:** exactly-once per (plan_id, change_set_hash)
- **Ordering:** per-plan_id
- **Idempotency-Key:** sha256(plan_id, change_set_hash)
- **Ack/Nack:** gateway ACK with exec_id; NACK on policy constraint or window violation
- **Timeouts/Retry:** ack<=60 s; step_timeout<=900 s; retries per step<=3 with exp backoff
- **Side-Effects:** optional PR auto-create/update when requires_pr:true; ticket comment with exec_id
- **HITL Token:** required for hitl_required:prod or CrownJewel targets
- **Observability:** trace_id, mission_id, decision_basis.confidence, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ConfigSet@1.3 | json_schema_uri=uri://schema/configset-1.3.json | sha256= | producers=E7 | consumers=Engine-GW-01 | accepts=1.1–1.3

Conformance: Normative.

OC-2: EnforcementResult (status + evidence) [Informative]

- **Producer(s):** E7 (or Engine-GW-01 on behalf)
- **Topic/Path:** sec.enforcement.result
- **Schema/Format: EnforcementResult@1.2** (exec_id, plan_id, change_set_hash, step_results[], post_checks[], re_scan, start_ts, end_ts, status in {success, partial, failed, rolled_back}, rollback_status, evidence_refs[], logs_uri, pr_refs[], ticket_refs[])
- **Classification:** C2 (C3 if sensitive device data present)
- **Delivery:** at-least-once
- **Ordering:** per-exec_id
- **Idempotency-Key:** sha256(exec_id)
- **Ack/Nack:** consumer ACK<=30 s; retry/backoff
- **Side-Effects:** update change ticket; append immutable audit record; notify owners
- **HITL Token:** none (reporting)
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EnforcementResult@1.2 | json_schema_uri=uri://schema/enforcement-result-1.2.json | sha256= | producers=E7, Engine-GW-01 | consumers=SOAR-01, SIEM-01, Tickets-01 | accepts=1.0–1.2

Conformance: Normative.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** E7, CAB/Owners Portal
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0 (plan_id or change_id, rationale, severity, requested_remedy, decision_rationale_url)

- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-plan_id
- **Idempotency-Key:** sha256(plan_or_change_id, dispute_id)
- **Side-Effects:** freeze rollout escalation pending review

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (IR integration) [Informative, optional]

- **Producer(s):** E7
- **Topic/Path:** sec.policy.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (outage or regression; failed rollback; verification miss)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (gating and blast-radius) [Informative, optional]

- **Producer(s):** E7
- **Topic/Path:** sec.enforcement.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (affected services, dependency graph hits, users impacted, rollback plan, thresholds)
- **Classification:** C1–C2

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Condition: When canary_required:true or impact_score >= threshold
schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (stakeholder loop) [Informative, optional]

- **Producer(s):** Owners Portal; E7 (aggregation)
- **Topic/Path:** sec.policy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (plan_id or exec_id; label={helpful|neutral|harmful}; notes)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, validating_plan, staging_canary, enforcing_batch, verifying, re_scanning, auditing, contestation_workflow, rolling_back, failed, closed }

- transition(idle -> validating_plan) on EnforcementPlan received or RCA hardening action
- transition(validating_plan -> staging_canary) when approvals present and window open
- transition(staging_canary -> enforcing_batch) when canary checks pass and HITL satisfied if required
- transition(enforcing_batch -> verifying) after each step batch completes
- transition(verifying -> re_scanning) when post_checks pass; else rolling_back
- transition(re_scanning -> auditing) on passing re-scan or acceptable residuals
- transition(any -> contestation_workflow) on PolicyDispute or stakeholder_disagreement_score >= 0.5
- transition(any -> rolling_back) when verification fails or outage detected

- transition(* -> failed) on timeout or policy violation; transition(auditing -> closed) when records written

timeouts: ack<=60 s; step_timeout<=900 s; verify<=300 s; rollback<=900 s

idempotency_key(ConfigSet) = sha256(plan_id, change_set_hash)

idempotency_key(EnforcementResult) = sha256(exec_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ConfigSet	Required	Always	Applies secure configurations
OC-2 EnforcementResult	Required	Always	Provides auditable outcomes
OC-3 PolicyDispute	Optional	Contestability enabled	Governance and appeals
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ChangeImpactReport	Conditionally Required	Canary required or impact_score >= threshold	Risk-aware gating
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions: Required = must implement; Conditionally Required = must implement when condition holds; Optional = may implement.

Policies and HITL gates [Informative]

- policy_refs: **CM-6**, **CM-2**, **RA-5** (+ internal baselines).
- **HITL required:** production scopes with CrownJewels, auth subsystem changes, org-wide network templates.

- **Automatic HITL escalation triggers:** `model_confidence < theta_low;`
`model_drift_detected = true;` `stakeholder_disagreement_score >= 0.5;`
`impact_score >= 0.7.`
- **Manual outside agent:** baseline redesign, new engine onboarding, long-lived exceptions.

SLOs and KPIs [Informative]

- `PlanAck_p95 <= 60 s`
- `VerifyPass_p95 <= 300 s`
- `Rollback_MTTR_p95 <= 15 min`
- `ChangeSuccessRate_30d >= 98 percent`
- `CanaryAbortRate_30d <= 3 percent`

Outputs index [Informative]

[OC-1 ConfigSet], [OC-2 EnforcementResult], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E7) [Informative]

Model and training profile [Informative]

`model_id=protect-enforcement-text-model;` `temperature=0.1;` `max_tokens_out=800`
`prompt_pack_id=baseline-enforcement-v1` (baseline rubric, engine allowlist, canary rules, rollback patterns)

RAG: `sources={baseline repos, engine docs, prior EnforcementResult logs, exception registry, RCA library};` `max_docs=12;` `min_similarity=0.78;` `citations required`

`fine_tuning/adapters: none initially;` `evaluate on success rate, rollback correctness,` `hallucination bounds`

`guardrails: enforce requires_pr:true if present;` `deny out-of-window;` `scope to mission region and selectors;` `require rollback_token`

Memory and state [Informative]

`working_memory.max_tokens=4k;` `eviction=recency_then_importance`

`episodic_memory: per mission_id journal (plans, execs, verifications, rollbacks),` `ttr=365d`

`semantic_memory: namespaces=["baselines","engines","exec-history","exceptions"];` `embeddings=text-embedding-sec-v1;` `k=10`

durable_state_store: event-sourced ledger; snapshot every 1 h
 consistency: exactly-once per (plan_id, change_set_hash) for ConfigSet; at-least-once for EnforcementResult
 idempotency: per Output Contracts

Decision and routing logic [Informative]

- severity_map = {"Low":0.25,"Medium":0.5,"High":0.75,"Critical":1.0}
- blast_radius = normalized fraction of targeted fleet in environment
- dependency_hits = normalized count of services affected
- service_disruption_est = probability from historical execs per engine and playbook
- enforcement_risk_score = $0.4 \text{blast_radius} + 0.3 \text{dependency_hits} + 0.3 \text{service_disruption_est}$
- choose canary.percent = $\min(10, \text{round}(100 * \max(0.05, 0.25 - \text{enforcement_risk_score})))$
- require_hitl_if = (enforcement_risk_score >= 0.7) or CrownJewel in scope or engine in {"network","auth"}
- rollback_required = true if any step modifies auth, network, or kernel parameters

Model Risk Management [Informative]

continuous_validation: daily goldens and adversarial change sets
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly drills on destructive configs and engine misuse
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why, evidence_refs, policy_refs, hashes, expected vs observed state
UI/API: expose classification_label, provenance.attestation, decision_rationale_url, pr_refs
audit_log_format: JSONL; stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-4) on outage, verification failure, or unsuccessful rollback; attach exec_id and diagnostics

Change Impact Assessment [Informative]

emit ChangeImpactReport (OC-5) when canary required or impact_score high; gate rollout escalation until thresholds pass or HITL approves

Stakeholder Feedback Loop [Informative]

ingest FeedbackIngestionEvent (OC-6); governance-reviewed updates tune prompt_pack; never auto-train on device logs containing sensitive user data

Data Sovereignty and Legal Hold [Informative]

respect region constraints from plan.scope; legal_hold=true extends retention and blocks purge of related results

Interfaces (links only) [Informative]

Consumes: EnforcementPlans; RCAFindings

Produces: OC-1 ConfigSet; OC-2 EnforcementResult; OC-3/4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance failure or abnormal drift; sandbox mode if attestation missing; batch caps (<= 200 nodes per batch; <= 5 percent of fleet per hour)

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of historical plans; negative tests (deny dangerous vars); rollback drills; drift verification

Deployment and lifecycle [Informative]

HPA on queue depth; per-engine concurrency caps; canary for new playbooks; auto-rollback on failed post-checks; SBOM + in-toto/SLSA; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-6, CM-2, RA-5); NIST SP 800-61 Rev. 2; NIST SP 800-137; CIS Controls v8; CIS Benchmarks; MITRE ATT&CK/D3FEND

MCP-Native Protocol Specification (E7) [Normative]

- **Native Protocol(s) Consumed:** EnforcementPlans (REST/Git/Artifact store); RCAFindings (REST/Object Storage)

- **Native Protocol(s) Produced:** ConfigSet (engine-gateway requests); EnforcementResult (status + evidence); audit events to SIEM/SOAR
- **MCP Context Fields:**
 - **Required:** mission_id; role="BaselineEnforcementAgent"; intent="implement"; constraints (requires_pr, change_window, canary_required, hitl_required, rollback_ttl_minutes); policy_refs; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; decision_basis; legal_hold
- **Enforcement Note:** PEPs must confirm open change window, valid co-sign/HITL for production and CrownJewel scopes, attestation present, and idempotency keys unique per plan/change set before executing.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules (OC-1..OC-6) for accepted ranges and EOL.
- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url, pr_refs exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

E8. Appsec Scanner Agent

Agent Blueprint [Informative]

Purpose: Perform SAST/DAST/IAST (and SCA/SBOM checks) in CI/CD on code and build artifacts; emit **AppSecFinding** and **FixRecommendation**; auto-gate builds.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Code Commits (Git Webhook/REST):** branch/ref, commit IDs, diffs, authors, changed paths; PR/merge metadata; repository visibility.
- **Build Artifacts (CI REST/Artifacts; SBOM CycloneDX/SPDX):** container image refs and digests, packages and versions, SBOM component graph, pipeline/job metadata (runner, stage).

Model training / knowledge (what the LLM relies on):

- Rubrics for vulnerability triage (CWE/CVE mapping, KEV flags, EPSS/industry exploitability), false-positive suppression patterns, policy gates (fail_on_critical, banned APIs, secrets).
- RAG over: historical findings and dispositions, secure-coding standards (OWASP ASVS, company patterns), SBOMs and dependency advisories, prior FixRecommendations. Do **not** train on proprietary source; fetch as evidence_refs on demand.
- Guardrails: read-only access to repos unless generating PR comments; network egress net_access:deny unless dynamic scan requires allowlisted targets; tool invocation constrained to scanner allowlist.

Decisions it makes (deterministic + model-assisted):

- **Scope selection:** from diff and repo policies choose SAST rulesets, DAST targets, IAST hooks, and SCA scope.
- **Finding normalization & de-dup:** map engine-specific issues to canonical AppSecFinding with CWE/CVE IDs; collapse duplicates across engines.
- **Risk & gate decision:** compute build_risk_score and decide **pass / soft-fail / hard-fail**; attach rationale.
- **Fix strategy:** prefer version upgrades with lowest break risk; propose code diffs for simple sinks/sources; suggest compensating controls if immediate fix unavailable.

Routing / where outputs go:

- **AppSecFinding** → CI event bus and security data lake; annotations for DevEx dashboards.
- **FixRecommendation** → PR comments/status checks; optional auto-fix branch/PR.
- **BuildGateDecision** → CI status context (commit status / check run) and artifact tags; optional ticket creation for hard-fail.

Automation scope vs. manual/HITL:

- Fully automated: SAST/SCA/SBOM parsing, dedup, risk scoring, status setting, PR comments for low/medium findings.
- **HITL required:** approving hard-fail overrides on production-bound branches; accepting risky refactors; merging auto-fix PRs in protected repos.

- Manual outside agent: exception governance, architectural refactors, library migration playbooks.

Security Domain: Protective Technologies & Hardening

Inputs (native protocols consumed) [Informative]

1. **Code Commits (Git Webhook/REST)** — push/PR events (changed files, metadata, refs)
2. **Build Artifacts (CI REST/Artifacts; SBOM CycloneDX/SPDX)** — images/packages plus SBOM graph

Example: Consumed Protocol — Code Commits (Git Webhook/REST) [Informative]

Native payload

```
{
  "ref": "refs/heads/main",
  "before": "9c3a5c7e1d3e2f1a...",
  "after": "9d3f1a2b7c4d5e6f...",
  "repository": {"full_name": "org/payments-api", "private": true},
  "pusher": {"name": "april.ng", "email": "april.ng@example.com"},
  "commits": [{
    "id": "9d3f1a2b7c4d5e6f...",
    "timestamp": "2025-08-15T14:58:12Z",
    "message": "Add login handler and JWT utils",
    "added": ["src/auth/login.js"],
    "modified": ["src/auth/jwt.js", "package.json"],
    "removed": []
  }],
  "head_commit": {
    "id": "9d3f1a2b7c4d5e6f...",
    "author": {"name": "April Ng", "email": "april.ng@example.com"},
```

```

    "url": "https://git.example.com/org/payments-api/commit/9d3f1a2..."
  }
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-incident-INC-45920",
    "thread_id": "uuid-ci-push-org/payments-api-9d3f1a2",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "AppSecScannerAgent",
    "intent": "assess",
    "policy_refs": ["SA-11", "RA-5", "SI-2", "SSDF"],
    "constraints": ["fail_build_on_critical:true", "timeout_seconds:900", "net_access:deny"],
    "decision_basis": {
      "evidence_refs": [
        "uri://git/org/payments-api/commit/9d3f1a2",
        "uri://diff/org/payments-api/9c3a5c7..9d3f1a2"
      ],
      "confidence": 0.96,
      "explanation_ref": "uri://kb/appsec/sast-scope-from-diff"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/protect/appsec-scanner-agent",
      "signing_kid": "kid-git-e8-01",
      "attestation_ref": "uri://slsa/attestations/ci-scan@sha256:git01"
    }
  }
}

```

```

    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... as above ... }
}

```

Example: Consumed Protocol — Build Artifacts (CI REST/Artifacts; SBOM CycloneDX) [Informative]

Native payload

```

{
  "ci_run_id": "gh-run-123456",
  "build_id": "build-2025-08-15-0913",
  "pipeline": {"system": "github_actions", "job": "build-and-scan", "stage": "test"},
  "artifact": {
    "type": "container_image",
    "name": "registry.example.com/payments/api:9d3f1a2",
    "digest":
"sha256:9e2f0c0b5a17c0d3f4a1e8e9b2e1390b0a2b4f6e1c7d8a9f0b1c2d3e4f5a6b7c"
  },
  "sbom": {
    "format": "CycloneDX", "version": "1.5",
    "components": [
      {"name": "jsonwebtoken", "version": "8.2.0", "purl":
"pkg:npm/jsonwebtoken@8.2.0", "licenses": ["MIT"]},
      {"name": "lodash", "version": "4.17.19", "purl": "pkg:npm/lodash@4.17.19", "licenses":
["MIT"]}
    ]
  },
}

```

```

"source": {"repo": "org/payments-api","ref": "refs/heads/main","commit": "9d3f1a2"}
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-incident-INC-45920",
    "thread_id": "uuid-ci-run-gh-run-123456",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "AppSecScannerAgent",
    "intent": "assess",
    "policy_refs": ["SA-11","RA-5","SI-2","SSDF"],
    "constraints": ["fail_build_on_critical:true","timeout_seconds:900","net_access:deny"],
    "decision_basis": {
      "evidence_refs": [
        "uri://ci/builds/build-2025-08-15-0913",
        "oci://registry.example.com/payments/api@sha256:9e2f0c...",
        "sbom://cyclonedx/gh-run-123456"
      ],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/appsec/sca-thresholds-and-gates"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/protect/appsec-scanner-agent",
      "signing_kid": "kid-ci-e8-02",
      "attestation_ref": "uri://slsa/attestations/ci-scan@sha256:ci02",

```

```

"supply_chain": {
  "slsa_level": "SLSA-3",
  "builder_id": "spiffe://ci/github-actions",
  "source_repo": "org/payments-api"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... as above ... }
}

```

Outputs (native) [Informative]

- **AppSecFinding:** normalized SAST/DAST/IAST/SCA results with evidence and component/source mapping.
- **FixRecommendation:** patch/upgrade/code-diff suggestions; PR comments and/or check-run annotations.
- **BuildGateDecision:** pass/soft-fail/hard-fail result exported to CI status context.

MCP context (required) [Informative]

mission_id (if **scan triggered during an incident**, **MUST equal the incident's mission_id**); role="AppSecScannerAgent"; intent="assess"; provenance (SPIFFE ID, signing KID, SLSA/SBOM attestations).

MCP context (optional) [Informative]

constraints (e.g., fail_build_on_critical, timeout_seconds, net_access); policy_refs (SA-11, RA-5, SI-2, SSDF); decision_basis; classification; legal_hold.

Enforcement note [Informative]

CI PEPs must verify signed provenance, honor fail_build_on_critical policies, restrict network during scans unless allowlisted, and ensure the mission_id binding for incident-scoped scans.

NIST SP 800-160v2 linkage [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Develop / Implement / Evaluate — continuous assurance of software components across the pipeline.

Automation feasibility [Informative]

High: fully automated in CI; HITL required only for override of hard-fail gates or risky auto-fix merges.

Output Contracts (merged) [Informative]

OC-1: AppSecFinding (normalized security finding) [Informative]

- **Producer(s):** E8
- **Topic/Path:** sec.appsec.finding (per repo/commit or build_id)
- **Schema/Format: AppSecFinding@1.4** (finding_id, repo, ref, commit, build_id, artifact_digest, engine, scan_type in {SAST,DAST,IAST,SCA}, severity, cwe_ids[], cve_ids[], kev_flag, epss_score, reachability in {none,static,dynamic}, location{file:line|url|component}, evidence_refs[], recommendation_ref, mission_id, classification_label, provenance.attestation)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per (repo, commit)
- **Idempotency-Key:** sha256(repo, commit, engine, location, cwe_or_cve)
- **Ack/Nack:** consumer ACK<=30 s; retry/backoff
- **Side-Effects:** index into security data lake; annotate PR with summary
- **HITL Token:** none
- **Observability:** trace_id, mission_id, decision_basis.confidence, kev_flag, epss_score
- **Retention/TTL:** 3 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AppSecFinding@1.4 | json_schema_uri=uri://schema/appsec-finding-1.4.json | sha256= | producers=E8 | consumers=CI-UI-01, SecLake-01, Tickets-01 |

accepts=1.2–1.4 (1.2 EOL 2026-12-31)

Conformance: Normative.

OC-2: FixRecommendation (actionable remediation) [Informative]

- **Producer(s):** E8
- **Topic/Path:** sec.appsec.fix and PR comment/check-run endpoints
- **Schema/Format: FixRecommendation@1.2** (finding_id, fix_type in {upgrade,patch,code_diff,config,compensating_control}, details{target,version|diff|policy}, break_risk in [0..1], auto_fix_branch, pr_comment_url, gates_satisfied[], mission_id)
- **Classification:** C1–C2
- **Delivery:** at-least-once
- **Ordering:** per finding_id
- **Idempotency-Key:** sha256(finding_id, fix_type, target)
- **Ack/Nack:** PR system ACK or HTTP 201; retry/backoff
- **Side-Effects:** optional auto-fix branch/PR; link to ticket if created
- **HITL Token:** required when auto-fix targets protected branches
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 2 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=FixRecommendation@1.2 | json_schema_uri=uri://schema/fix-recommendation-1.2.json | sha256= | producers=E8 | consumers=Git-Checks-01, DevPortal-01 | accepts=1.0–1.2

Conformance: Normative.

OC-3: BuildGateDecision (CI status) [Informative]

- **Producer(s):** E8
- **Topic/Path:** sec.appsec.build_gate and CI status contexts

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Schema/Format: BuildGateDecision@1.1** (repo, commit, build_id, gate_policy_id, decision in {pass,soft_fail,hard_fail}, failing_findings[], thresholds{sev_max, kev_required, epss_min, reachability_required}, rationale, links{report_url, pr_check_url})
- **Classification:** C1
- **Delivery:** exactly-once per (repo, commit, build_id)
- **Ordering:** per (repo, commit)
- **Idempotency-Key:** sha256(repo, commit, build_id, gate_policy_id)
- **Ack/Nack:** CI status ACK; retry/backoff
- **Side-Effects:** tag artifact (compliance=pass|fail); open ticket on hard-fail
- **HITL Token:** required to override **hard_fail** on protected branches
- **Retention/TTL:** 1 year

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When CI gating is enabled or fail_build_on_critical:true
 schema_id=BuildGateDecision@1.1 | json_schema_uri=uri://schema/build-gate-decision-1.1.json | sha256= | producers=E8 | consumers=CI-01, ArtifactReg-01 | accepts=1.0–1.1

Conformance: Normative when condition is met.

OC-4: PolicyDispute (Explainability & Contestability) [Informative, optional]

- **Producer(s):** Dev Portal, E8 (on request)
- **Topic/Path:** sec.policy.contestation
- **Schema/Format:** PolicyDispute@1.0 (repo, commit, finding_ids[], rationale, requested_remedy)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional | **Condition:** contestability enabled

OC-5: IRPolicyViolationEvent (IR integration) [Informative, optional]

- **Producer(s):** E8
- **Topic/Path:** sec.policy.incident (e.g., gate bypass detected; high-risk artifact promoted)

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional | **Condition:** IR/SIEM integration present

OC-6: FeedbackIngestionEvent (stakeholder loop) [Informative, optional]

- **Producer(s):** Review portals; E8 (aggregation)

- **Topic/Path:** sec.policy.feedback

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional | **Condition:** feedback workflow enabled

State machine (concise) [Informative]

states = { idle, scoping, scanning, aggregating_findings, recommending_fixes, gating, auditing, contestation_workflow, failed, closed }

- transition(idle -> scoping) on Code Commit or Build Artifact event
- transition(scoping -> scanning) when scope and tools selected and constraints validated
- transition(scanning -> aggregating_findings) when engines complete or timeout
- transition(aggregating_findings -> recommending_fixes) after de-dup and normalization
- transition(recommending_fixes -> gating) once risk computed and fixes prepared
- transition(gating -> auditing) after CI status set and artifacts tagged
- transition(any -> contestation_workflow) on PolicyDispute or override attempt
- transition(* -> failed) on policy violation or provenance failure; transition(auditing -> closed) after logs written

timeouts: engine_timeout<=900 s; aggregate<=60 s; gate_status<=15 s

idempotency_key(AppSecFinding) = sha256(repo, commit, engine, location, cwe_or_cve)

idempotency_key(BuildGateDecision) = sha256(repo, commit, build_id, gate_policy_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 AppSecFinding	Required	Always	Canonicalized security findings
OC-2 FixRecommendation	Required	Always	Actionable remediation for devs
OC-3 BuildGateDecision	Conditionally Required	CI gating enabled or fail_build_on_critical:true	Enforces release quality & safety
OC-4 PolicyDispute	Optional	Contestability enabled	Governance & appeals
OC-5 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions: Required = must implement; Conditionally Required = must implement when condition holds; Optional = may implement.

Policies and HITL gates [Informative]

- policy_refs: **SA-11, RA-5, SI-2, SSDF** (+ internal policies).
- **HITL required:** override of hard-fail on protected branches; auto-fix merge on critical paths; promotion of artifact with kev_flag=true or reachability=dynamic.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; drift_detected=true; stakeholder_disagreement_score >= 0.5.

SLOs and KPIs [Informative]

- ScanComplete_p95 <= 10 min
- FalsePositiveRate_30d <= 5 percent
- MeanTimeToFirstFixSuggestion_p95 <= 60 s

- GateDecisionLatency_p95 <= 15 s

Outputs index [Informative]

[OC-1 AppSecFinding], [OC-2 FixRecommendation], [OC-3 BuildGateDecision], [OC-4 PolicyDispute], [OC-5 IRPolicyViolationEvent], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (E8) [Informative]

Model and training profile [Informative]

model_id=protect-appsec-text-model; temperature=0.1; max_tokens_out=700
 prompt_pack_id=appsec-scanner-v1 (triage rubric, gating thresholds, fix patterns)
 RAG: sources={findings history, SBOMs, advisories, secure-coding guides};
 max_docs=12; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; evaluate on triage precision/recall and gate accuracy
 guardrails: net_access:deny by default; allowlist DAST targets; forbid secret exfiltration;
 PR comment scope limited to changed lines

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id/build journal (engines run, outputs, overrides),
 ttl=365d
 semantic_memory: namespaces=["findings","fixes","policies","sbom"];
 embeddings=text-embedding-sec-v1; k=10
 durable_state_store: append-only JSONL audit; snapshot per build_id
 consistency: at-least-once (findings/fixes); exactly-once (BuildGateDecision per build)

Decision and routing logic [Informative]

- sev_score ∈ {Info:0, Low:0.25, Medium:0.5, High:0.75, Critical:1.0}
- reachability_score ∈ {none:0, static:0.3, dynamic:0.7}
- exposure_score = 1.0 if internet_facing=true else 0.4 if internal else 0.2
- runtime_score = 0.7 if exploit_observed=true else 0
- kev_bonus = 0.2 if kev_flag=true else 0
- age_penalty = min(0.2, days_open / 180 * 0.2)

- $\text{build_risk_score} = 0.4\text{sev_score} + 0.2\text{reachability_score} + 0.2\text{exposure_score} + 0.15\text{runtime_score} + 0.05*\text{kev_bonus} - \text{age_penalty}$
- gate decision: hard_fail if (sev>=High and (reachability>=static or kev_flag)) or build_risk_score >= 0.7; soft_fail if build_risk_score in [0.5,0.7)

Model Risk Management [Informative]

continuous_validation: daily goldens + adversarial prompts (synthetic repos with traps)

thresholds: eval_pass_rate >= 99.5 percent; below → auto_HITL

red_team_cycle: monthly (e.g., hidden-sink patterns, confused-deputy scans)

rollback_policy: eval_drop >= 1.5 pp for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; policies; hashes; gate thresholds

UI/API: expose classification_label, provenance.attestation, decision_rationale_url, links to PR checks and reports

audit_log_format: JSONL stable fields; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-5) if gate bypass detected or artifact with hard-fail is promoted; attach build_id and artifact digest

Change Impact Assessment [Informative]

when fix requires dependency upgrade, compute downstream break risk and emit as notes in FixRecommendation; if high, request HITL

Stakeholder Feedback Loop [Informative]

ingest FeedbackIngestionEvent (OC-6); curator-approved updates refine prompt_pack; never auto-train on proprietary source

Data Sovereignty and Legal Hold [Informative]

enforce data_residency via CI runner region; set legal_hold=true for incident scans to extend retention

Interfaces (links only) [Informative]

Consumes: Code Commits; Build Artifacts/SBOM

Produces: OC-1 AppSecFinding; OC-2 FixRecommendation; OC-3 BuildGateDecision; OC-4/5/6 as adopted

Safety and abuse prevention [Informative]

kill_switch on provenance failure or anomalous gate rate; sandbox dynamic scans; cap PR comment volume; secret-redaction in outputs

Testing and validation [Informative]

contract tests from Schema Capsules; offline replay of historical builds; seeded repos for regression; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; per-repo concurrency caps; canary for new rulepacks; SBOM attestations required; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SA-11, RA-5, SI-2); NIST SSDF (SP 800-218); NIST SP 800-61 Rev. 2; SLSA; CycloneDX 1.5; SPDX 2.x; OWASP ASVS; MITRE CWE/CVE

MCP-Native Protocol Specification (E8) [Normative]

- **Native Protocol(s) Consumed:** Code Commits (Git Webhook/REST); Build Artifacts (CI REST/Artifacts; SBOM CycloneDX/SPDX)
- **Native Protocol(s) Produced:** AppSecFinding; FixRecommendation; BuildGateDecision
- **MCP Context Fields:**
 - **Required:** mission_id (**MUST bind to incident mission_id when scan is incident-triggered**); role="AppSecScannerAgent"; intent="assess"; provenance (SPIFFE ID, signing KID, SLSA/SBOM attestations)
 - **Optional:** constraints; policy_refs; decision_basis; classification; legal_hold
- **Enforcement Note:** CI/CD PEPs MUST verify signed provenance; MUST honor gating policies (fail_build_on_critical, protected-branch overrides require HITL token); MUST bind incident scans to the incident mission_id.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; accepted version ranges and EOL dates live in each Schema Capsule.

- **Example payloads:** native and MCP-wrapped examples above are canonical.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url`, `report/pr_check` links exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.